

국립수산과학원 정보보안업무 지침

제정 2024.04.15. 국립수산과학원 훈령 제670호

개정 2026.02.24. 국립수산과학원 훈령 제694호

제1장 총칙

제1조(목적) 이 지침은 「국가정보원법」, 「사이버안보 업무규정」, 「국가사이버안전관리규정」, 「국가 정보보안 기본지침」 및 「해양수산부 정보보안업무규정」에 따라 국립수산과학원에서 수행해야 할 정보보안과 관련한 기본업무를 규정함을 목적으로 한다.

제2조(정의) 이 규정에서 사용하는 용어의 뜻은 다음과 같다.

1. "정보보안"이란 국립수산과학원(이하 "과학원"이라 한다) 본원 및 소속기관의 기능 유지 등을 목적으로 정보통신망 및 정보시스템을 통해 수집, 가공, 저장, 검색 등 송수신되는 정보의 유출, 위조, 변조 및 훼손 등을 방지하기 위하여 관리적·물리적·기술적 수단을 마련하는 모든 행위로서 다음 각 목의 사항을 포함한다.

가. 「국가정보원법」 제4조제1항제4호에 따른 사이버공격 및 위협에 대한 예방 및 대응

나. 「전자정부법」 제56조에 따른 정보통신망과 행정정보 등의 보안
다. 「정보통신기반 보호법 시행령」 제5조제4항제1호 각 목에 해당하는 주요정보통신기반시설의 보호

라. 「공공기록물 관리에 관한 법률 시행령」 제5조에 따른 전자기록물의 보안

마. 「국가사이버안전관리규정」 제2조제3호에 따른 사이버안전

2. "소속기관"이란 「국립수산과학원 기본운영규정」에 따른 소속기관을 말한다.

3. "부서"란 「국립수산과학원 기본운영규정」에 따른 각 과(센터), 연구소, 연구센터 등 정보보안관리 대상 단위를 말한다.

4. "정보보안담당관"이란 과학원의 정보보안업무를 총괄하는 사람을 말한다.

5. "보안담당관"이란 「보안업무규정」 제43조에 따른 보안담당관을 말한다.

6. "정보통신망"이란 「사이버안보 업무규정」 제2조제1호에 따른 정보통신망을 말한다.

7. "내부망"이란 과학원의 업무 수행을 위하여 인터넷과 별도로 분리하여 구축한 업무 전용(專用) 정보통신망을 말한다.

8. "기관 인터넷망"이란 제2조제21호에 따른 공무원 등의 업무 활용 또는 공개 서버 운용을 주목적으로 인터넷과 연동하여 구축한 정보통신망을 말한다.

9. "상용(商用) 인터넷망"이란 기관 인터넷망과 별도로 분리된 인터넷망으로서, 제2조제21호에 따른 공무원 등이나 민원인 등의 보편적인 편의성을 위하여 인터넷에 연동하여 구축한 정보통신망을 말한다.

10. "정보시스템"이란 「전자정부법」 제2조제13호에 따른 정보시스템을 말한다.
11. "휴대용 저장매체"란 CD·외장형 하드디스크·USB메모리 등 정보를 저장할 수 있는 것으로 PC·서버 등의 정보시스템과 분리할 수 있는 기억장치를 말한다.
12. "업무자료"란 다음 각 목의 어느 하나에 해당하는 것을 말한다.
- 가. 「전자정부법」 제2조제6호에 따른 행정정보 및 같은 법 제2조제7호에 따른 전자문서
- 나. 「공공기록물 관리에 관한 법률 시행령」 제2조제2호에 따른 전자기록물
- 다. 그 밖에 다른 법령에 따라 제2조제21호에 따른 공무원 등이 직무상 작성·취득하였거나 보유·관리하는 자료로서 전자적으로 처리되어 부호·문자·음성·음향·영상 등으로 표현된 것
13. "비밀"이란 업무자료 중에서 「보안업무규정」 제4조에 따라 분류된 비밀을 말한다.
14. "대외비"란 업무자료 중에서 「보안업무규정 시행규칙」 제16조제3항에 따라 분류된 대외비를 말한다.
15. "비공개 업무자료"란 비밀 및 대외비를 제외한 업무자료 중에서 다음 각 목의 어느 하나에 해당하는 자료 또는 정보를 말한다.
- 가. 「공공기관의 정보공개에 관한 법률」 제9조제1항에 따른 비공개 대상 정보

나. 국회 소속 공무원(「국회의원수당 등에 관한 법률」 제9조에 따른 보좌직원을 포함한다) 또는 「지방자치법」 제30조에 따른 지방의회 소속 공무원의 직무상 요구에 따라 작성 또는 취득한 자료다. 가목에 따른 비공개 대상 정보의 주요 내용이 기술된 문장 또는 문구

16. "공개 업무자료"란 업무자료 중에서 비밀 및 대외비와 비공개 업무자료를 제외한 모든 자료 또는 정보(「공공데이터의 제공 및 이용 활성화에 관한 법률」 제19조에 따라 공표된 공공데이터를 포함한다)를 말한다.

17. "전산기계실"이란 과학원의 정보시스템을 운영하기 위해 전산장비, 통신장비, 보안장비, 부대장비 등이 설치된 장소를 말한다.

18. "정보보호시스템"이란 「지능정보화 기본법」 제2조제15호에 따른 정보보호시스템을 말한다.

19. "안전성 검증필 제품"이란 국가정보원장이 국가용 보안요구사항을 만족하는지 등 안전성을 확인하여 제20조에 따른 안전성 검증필 제품 목록에 등재한 정보통신제품을 말한다.

20. "보안적합성 검증"이란 제19조제1항제3호의 보안기능이 있는 정보통신제품의 실제 적용·운용 이전에 시험 등의 방법으로 안전성을 검증하는 활동을 말한다.

21. "공무원 등"이란 과학원에 근무 중인 다음 각 목의 어느 하나에 해당하는 사람을 말한다.

- 가. 「국가공무원법」 제2조에 따른 국가공무원
 - 나. 「지방공무원법」 제2조에 따른 지방공무원
 - 다. 공무원직 근로자 및 기간제 근로자
 - 라. 「청원경찰법」 제2조에 따른 청원경찰
22. "개별사용자"란 정보보안담당관으로부터 정보통신망 또는 정보시스템에 대한 접근 또는 사용 허가를 받은 공무원 등과 정보보안담당관과 계약에 따라 정보통신망 또는 정보시스템에 대한 접근 또는 사용 허가를 받은 사람을 말한다.
23. "암호자제"란 비밀의 보호 및 정보통신 보안을 위하여 암호기술이 적용된 장치나 수단으로서 I 급, II 급 및 III 급비밀 소통용 암호자제로 구분되는 장치나 수단을 말한다.
24. "검증필 암호모듈"이란 「사이버안보 업무규정」 제9조제2항 및 제3항, 「전자정부법 시행령」 제69조와 「암호모듈 시험 및 검증지침」에 따라 국가정보원장이 안전성을 확인하여 제21조에 따른 목록에 등재한 상용 암호모듈을 말한다.
25. "사이버공격"이란 「사이버안보 업무규정」 제2조제2호에 따른 행위를 말한다.
26. "보안관제"란 사이버공격을 실시간으로 즉시 탐지, 분석 및 대응하는 일련의 활동을 말한다.
27. "보안관제센터"란 일정한 수준의 시설 및 장비와 이를 운영하기 위한 전문 또는 전문인력을 갖추고 보안관제업무를 수행하는 조직을

말한다.

28. "취약점"이란 사이버공격에 악용되어 관리자가 설정한 접근 권한 이외의 정보를 열람·취득하게 하거나 보안기능을 회피 가능하게 하는 정보통신망·정보시스템의 결함을 말한다.

29. "클라우드컴퓨팅(Cloud Computing)"이란 집적·공유된 정보통신 기기, 정보통신설비, 소프트웨어 등 정보통신자원을 이용자의 요구나 수요변화에 따라 정보통신망을 통하여 신축적으로 이용할 수 있도록 하는 정보처리체계를 말한다.

30. "모바일 단말관리(Mobile Device Management, MDM)"란 휴대전화나 태블릿, 휴대용 컴퓨터와 같은 모바일 기기를 보호, 관리, 감시, 지원하는 일련의 과정을 말한다.

제3조(적용범위) 이 지침은 과학원 본원 및 소속기관에 적용하며, 정보통신망·정보시스템과 관련한 업무를 위임 또는 위탁받은 기관 및 단체의 정보보안업무에 적용할 수 있다.

제4조(책무) ① 국립수산과학원장(이하 "원장"이라 한다)은 국가안보 및 국익과 관련된 정보(업무자료를 포함한다. 이하 같다)와 과학원 정보통신망을 보호하기 위하여 보안대책을 마련해야 하며 정보보안에 대한 책임을 진다.

② 원장은 공무원 등에 대한 근무성적 또는 성과 평가를 실시할 경우 이 지침을 준수하는지 등을 반영할 수 있다.

제4조의2(다른 지침과의 관계) 본원 및 소속기관의 정보보안업무에

관해서는 다른 법령 및 행정규칙에 특별한 규정이 있는 경우를 제외하고는 이 지침에서 정하는 바에 따른다.

제5조(정보보안담당관 운영) ① 정보보안담당관은 「해양수산부 정보보안업무규정」에 따라 다음과 같이 지정하며 보직과 동시에 과학원의 정보보안담당관으로 한다.

1. (정) 연구협력과장
2. (부) 연구협력과 전산관리팀장

② 정보보안담당관은 다음 각 호의 업무를 총괄 수행한다.

1. 정보보안 정책·계획의 수립·시행 및 정보보안내규 제정·개정
2. 정보보안 전담조직 관리, 전문인력 및 관련예산 확보
3. 정보화사업 보안성 검토 및 보안적합성 검증 총괄
4. 전산기계실, 정보통신망 현황자료 등에 관한 보안관리 총괄
5. 사이버공격 대응훈련 총괄
6. 정보보안 사고대응 총괄
7. 정보보안교육 총괄 및 ‘사이버보안진단 주간’ 계획 수립·시행
8. 본원 및 소속기관에 대한 정보보안감사
9. 분임정보보안담당관 업무 감독
10. 그 밖에 정보보안과 관련한 사항

③ 원장은 정보보안담당관이 직무를 효율적으로 수행할 수 있도록 각 부서의 장을 분임정보보안담당관으로 지정한다.

④ 정보보안담당관은 제2항 각 호에 해당하는 업무를 수행할 때 필요

한 경우 해당 업무의 일부를 분임정보보안담당관에게 위임할 수 있다.

⑤ 분임정보보안담당관은 다음 각 호에 해당하는 업무를 수행해야 한다.

1. 내부망 자료를 기관 인터넷망으로 전송(휴대용 저장매체를 이용한 자료 반출을 포함한다)할 경우 사전 또는 사후 승인
2. ‘사이버보안진단 주간’에 부서의 정보통신망과 정보시스템의 보안이 취약한지 확인 등 보안진단
3. 제41조제2항 및 제3항에 따른 보안대책의 적절성 수시 점검·보완
4. 부서에서 홈페이지 등에 업무자료를 게시할 경우 자료 내용을 사전 검토
5. 부서에서 운용하는 홈페이지에서 비밀, 대외비, 비공개 업무자료가 무단 게시되었는지를 정기적으로 점검
6. 부서 개별사용자가 제71조제2항 각 호에 해당하는 보안대책을 준수하는지를 정기적으로 점검하고 개선 조치
7. 부서 개별사용자의 휴대용 저장매체 무단 반출, 미(未)등록 휴대용 저장매체를 사용하는지 등 보안관리 실태 정기 점검
8. 부서의 이동통신단말기 또는 이동통신망 접속장치(USB형 등)를 내부망 및 기관 인터넷망에 연결하는지 수시 점검
9. 부서의 복합기 유지보수를 할 경우 참석·감독
10. 부서에서 제66조에 따른 상용 정보서비스 관련 보안규정을 준수하는지 수시 점검

11. 부서에서 제71조에 따른 기관 인터넷PC에 편집이 가능한 문서프로그램 사용관련 보안규정을 준수하는지 수시 점검

12. 그 밖에 부서의 정보보안과 관련한 사항

제6조(연도 추진계획 수립) 정보보안담당관은 「연도 정보보안업무 세부추진계획」을 수립하여 해양수산부장관에게 제출해야 한다.

제7조(정보보안감사) ① 정보보안담당관은 본원 및 소속기관의 정보보안업무 및 활동을 조사·점검하기 위하여 연 1회 이상 정보보안감사를 실시해야 한다.

② 정보보안담당관은 제1항에 따른 정보보안감사를 실시할 경우 제86조 각 호의 사항을 활용할 수 있다.

③ 정보보안담당관은 정보보안감사 이외에 정보보안업무에 필요한 경우 정보보안 점검방문을 실시할 수 있으며, 점검방문의 대상, 주관기관 및 방식은 제2항을 준용한다.

제8조(정보보안교육) ① 정보보안담당관은 정보보안에 대한 경각심을 높이기 위하여 정보보안교육 계획을 수립하여 연 1회 이상 모든 공무원 등을 대상으로 1시간 이상의 교육(온라인 교육을 포함한다)을 실시해야 한다.

② 제1항에 따라 모든 공무원 등은 특별한 사유가 없으면 연 1회 1시간 이상의 정보보안교육을 이수해야 한다.

제9조(사이버보안진단 주간) ① 정보보안담당관은 매월 세 번째 수요일이 포함된 주간을 ‘사이버보안진단 주간’으로 지정·시행해야 한다.

다만, 부득이한 사유로 해당 주간에 시행하지 못할 경우 일정을 변경하여 시행할 수 있다.

② 분임정보보안담당관은 ‘사이버보안진단 주간’에 부서의 정보통신망과 정보시스템의 보안이 취약한지 확인 등 보안진단을 실시해야 한다.

제2장 정보화사업 보안

제1절 사업 계획

제10조(보안책임) ① 정보통신망 또는 정보시스템을 개발·구축·운영·유지보수하는 사업(「지능정보화 기본법」 제11조제1항에 따른 지능정보화계획에 따른 사업을 포함한다. 이하 "정보화사업"이라 한다)을 담당하는 부서의 장(이하 "정보화사업담당관"이라 한다)은 해당 정보화사업에 대한 보안관리를 수행해야 한다.

② 정보화사업담당관은 정보화사업에 대한 보안관리 책임을 지고 관리·감독해야 한다.

③ 정보보안담당관 및 보안담당관은 여러 가지 정보화사업과 관련한 보안대책의 적절성을 평가하고 정보화사업 수행 전반의 보안대책을 이행하는지를 점검하여 필요한 경우 정보화사업담당관에게 시정을 요구할 수 있다.

제11조(보안대책 수립) 정보화사업담당관은 정보통신망 또는 정보시스템을 구축·운영하기 위한 정보화사업 계획을 수립할 경우 다음 각 호의 사항을 포함한 보안대책을 수립·시행해야 한다.

1. 보안관리체계(조직, 인원 등) 구축 등 관리적 보안대책
2. 설치·운영장소 보안관리 등 물리적 보안대책
3. 정보통신망 또는 정보시스템의 구성요소별 기술적 보안대책
4. 국가정보원장이 개발하거나 안전성을 확인한 암호자재, 검증필 암호모듈 및 정보보호시스템 도입·운영계획
5. 긴급사태 대비 및 재난복구 계획
6. 용역업체 작업장소에 대한 보안대책
7. 온라인 개발 또는 온라인 유지보수가 필요하다고 판단할 경우, 제28조 또는 제50조에 따른 보안대책
8. 누출금지정보 보안관리 방안

제12조(제안요청서 기록사항) ① 정보화사업담당관은 용역업체에 정보화사업을 발주하기 위하여 제안요청서를 작성할 경우 다음 각 호의 사항을 포함해야 한다.

1. 용역업체 작업장소에 대한 보안요구사항
 2. 온라인 개발 또는 온라인 유지보수가 필요하다고 판단할 경우, 제28조 또는 제50조에 따른 보안 준수사항
 3. 누출금지정보 목록
 4. 용역업체가 누출금지정보를 제외한 소프트웨어 산출물을 제3자에게 제공할 경우 발주자의 승인절차
- ② 제1항제3호에 따른 누출금지정보 목록을 작성할 경우 다음 각 호의 사항을 포함해야 한다.

1. 정보시스템 내외부 아이피(IP) 주소 현황
2. 정보통신망 구성도 및 정보시스템 구성 현황
3. 개별사용자의 계정·비밀번호 등 정보시스템 접근권한 정보
4. 정보통신망 또는 정보시스템 취약점 분석·평가 결과물
5. 정보화사업 용역 결과물 및 관련 프로그램 소스코드(외부에 유출될 경우 국가안보 및 국익을 해칠 우려가 있는 중요 용역사업에 한정한다)
6. 암호자재, 암호가 주 기능인 제품 및 정보보호시스템 도입·운용 현황
7. 정보보호시스템 및 네트워크장비 설정 정보
8. 「공공기관의 정보공개에 관한 법률」 제9조제1항에 따라 비공개 대상 정보로 분류한 해당 기관의 내부분서
9. 「개인정보보호법」 제2조제1호에 따른 개인정보
10. 「보안업무규정」 제4조에 따른 비밀 및 「보안업무규정 시행규칙」 제16조제3항에 따른 대외비
11. 그 밖에 정보보안담당관이 공개가 불가하다고 판단한 자료

제2절 보안성 검토

제13조(검토 시기 및 절차) ① 정보화사업담당관은 정보화사업을 수행할 경우 정보화사업과 관련한 보안대책의 적절성을 평가하기 위하여 사업 계획단계(사업 공고 전을 말한다)에서 보안성 검토 절차를 이행

해야 한다.

② 정보화사업담당관은 제1항에 따른 보안성 검토를 위하여 정보보안 담당관을 거쳐 제14조제1항 및 제2항에 따른 보안성 검토 기관의 장에게 검토를 의뢰하거나 자체적으로 실시해야 한다.

③ 보안성 검토는 서면 검토를 원칙으로 하며 보안성 검토 기관의 장이 필요하다고 판단하는 경우 정보화사업담당관이 추진하는 현장 확인을 실시할 수 있다.

제14조(검토 기관) ① 정보화사업담당관은 다음 각 호에 해당하는 정보화사업을 추진할 때 해양수산부장관을 거쳐 국가정보원장에게 보안성 검토를 의뢰해야 한다.

1. 비밀·대외비를 유통·관리하기 위한 정보통신망 또는 정보시스템 구축
2. 국가정보원장이 개발하거나 안전성을 확인한 암호자재를 적용하는 정보통신망 또는 정보시스템 구축
3. 외교·국방 등 국가안보상 중요한 정보통신망 또는 정보시스템 구축
4. 100만명 이상의 개인에 대한 「개인정보보호법」상 민감정보 또는 고유식별정보를 처리하는 정보시스템 구축
5. 주요정보통신기반시설로 지정이 필요한 정보통신기반시설 구축
6. 제51조의2에 따른 제어시스템 도입
7. 재난관리·국민안전·치안유지·비상사태 대비 등 국가위기 관리

와 관련한 정보통신망 또는 정보시스템 구축

8. 국가정보통신망 등 여러 기관이 공동으로 활용하기 위한 정보통신망 또는 정보시스템 구축
9. 행정정보, 국가지리, 환경정보 등 국가 차원의 주요 데이터베이스 구축
10. 정상회의, 국제회의 등 국제행사를 위한 정보통신망 또는 정보시스템 구축
11. 내부망 또는 폐쇄망을 인터넷 또는 다른 정보통신망과 연동하는 사업
12. 내부망과 기관 인터넷망을 분리하는 사업
13. 통합데이터센터·보안관제센터 구축
14. 제2조제8호에 따른 기관 인터넷망 등 공무원 등이 업무상 목적으로 활용하도록 하기 위한 인터넷망(제41조제1항제1호에 따른 업무용 무선랜 형태를 포함한다) 및 이동통신망(HSDPA, WCDMA, LTE, 5G 등)의 구축
15. 원격근무시스템 구축
16. 「전자정부법」 제54조의2 및 「클라우드컴퓨팅 발전 및 이용자 보호에 관한 법률」 제20조에 따라 클라우드컴퓨팅서비스제공자의 클라우드컴퓨팅서비스(이하 "민간 클라우드컴퓨팅서비스"라 한다)를 이용하는 사업
17. 남북 회담 및 협력사업 등을 위한 북한지역 내 정보통신망 또는 정

보시시스템 구축

18. 외국에 개설하는 사무소 운영을 위한 정보통신망 또는 정보시스템
구축

19. 첨단 정보통신기술을 활용하는 정보화사업으로서 국가정보원장이
해당 기술의 안전성 확인이 필요하다고 지정하는 사업

② 정보화사업담당관은 다음 각 호에 해당하는 정보화사업에 대해서
는 해양수산부장관에게 보안성 검토를 의뢰해야 한다.

1. 해양수산부장관이 국가정보원장으로부터 보안성 검토를 위임받은
사업

2. 홈페이지 및 전자우편 등 웹기반 정보시스템 구축

3. 인터넷전화시스템 구축

4. 다른 기관의 정보통신망 또는 정보시스템과 연동하여 정보의 소통
또는 서비스를 제공하는 정보시스템 구축

5. 제2조제9호에 따른 상용 인터넷망(제41조제1항제2호 또는 제3호에
따른 무선랜 형태를 포함한다)의 구축

6. 내부망에 구축하는 공무원 등의 인사·복지시스템

7. 주요정보통신기반시설 취약점 분석·평가, 정보보안컨설팅 등 용역
사업

8. 기존 분리된 내부망·기관 인터넷망 간 자료전송시스템 구축 등 후
속사업

9. 대규모 백업(BACKUP)·재해복구센터 구축

10. 제43조제1항에 따른 영상회의시스템을 내부망 또는 기관 인터넷망과 분리하여 구축하는 경우
11. 제77조에 따른 영상정보처리기기를 같은 조 제3항 본문에 따라 인터넷과 분리하여 구축하는 경우
12. 백업시스템 구축
13. 대민(對民) 콜센터시스템 구축
14. 그 밖에 정보보안담당관이 필요하다고 판단하는 정보통신망 또는 정보시스템 구축

제15조(검토 생략) ① 정보화사업담당관은 다음 각 호에 해당하는 정보화사업에 대해서는 보안성 검토 절차의 이행을 생략할 수 있다. 이 경우 정보화사업담당관은 관련 설명서·지침 등을 준수하는 등 자체 보안대책을 수립·시행해야 한다.

1. 제14조제1항 및 제2항 각 호의 정보화사업에 해당하지 않는 단순 장비·물품 도입
2. 제14조에 따른 보안성 검토를 마친 정보화사업의 정보통신망 구성을 변경하지 않는 범위에서 다음 각 목의 사항을 포함한 후속운영·유지보수·컨설팅(단일 회선의 이중화는 이 호를 적용할 때 정보통신망 구성의 변경이 아닌 것으로 본다)
 - 가. 서버·스토리지·네트워크장비 등 장비 노후화로 인한 단순 장비바꿈
 - 나. 전화기·무전기·CCTV 등 통신·영상기기의 노후화로 인한 단

순 장비 바꿈

다. 기존 운용하던 정보보호시스템을 같은 보안기능을 보유한 다른 정보보호시스템으로 교체

3. 다년도에 걸쳐 계속되는 사업으로서 사업 시작 당시 보안성검토를 마친 후 사업 내용의 변동 없이 계속 추진하는 운영·유지사업

4. PC·프린터 및 상용 소프트웨어 등 단순 제품 교체

② 정보화사업담당관은 제1항제2호부터 제4호까지에 해당하는 정보화사업을 수행할 경우 기존 보안성 검토결과를 지켜야 한다.

제16조(제출 문서) 정보화사업담당관은 제13조제2항에 따라 보안성 검토를 의뢰할 경우 다음 각 호의 사항이 포함된 문서를 제출해야 한다.

1. 사업계획서(사업목적 및 추진계획을 포함한다)
2. 제안요청서
3. 정보통신망 구성도(필요시 IP주소체계를 추가한다)
4. 산출명세서
5. 자체 보안대책

제17조(검토결과 조치) ① 정보화사업담당관은 제14조의 검토 기관으로부터 통보받은 보안성 검토 결과를 반영하여 보안대책을 보완해야 한다.

② 정보보안담당관은 제1항에 따른 보안성 검토결과를 정보화사업담당관이 반영하였는지 확인하기 위하여 현장 점검을 실시할 수 있다.

제3절 제품 도입

제18조(정보시스템 관리책임자 및 관리자 지정) ① 정보시스템(PC·서버·네트워크장비·정보통신기기 등을 포함한다)을 도입·운용할 경우 해당 정보시스템의 관리책임자 및 관리자를 지정·운영해야 하며, 관리책임자는 정보시스템을 실제 운용하는 부서의 장이 되고 관리자는 업무담당자가 된다.

② 정보시스템 관리자는 별지 제3호 서식에 따른 정보시스템 관리대장을 수기(手記) 또는 전자적으로 작성·관리해야 한다.

제19조(정보통신제품 도입) ① 정보시스템 관리책임자는 정보통신망 및 정보시스템 등을 보호하기 위하여 보안기능이 있는 다음 각 호에 해당하는 정보통신제품을 도입할 수 있다.

1. 제20조에 따른 안전성 검증필 제품 목록에 등재되어 있는 제품
2. 비밀이 아닌 업무자료의 암호·복호화를 목적으로 한 경우 별표 2를 만족하는 제품
3. 제1호 및 제2호에 해당하지 않는 정보통신제품 중에서 국가정보원장이 별도로 공지하는 도입요건을 만족하는 제품
4. 제품유형의 특성상 보안기능의 비중이 낮아, 정보보안담당관이 자유롭게 도입·운용이 가능한 ‘단순 보안기능 제품유형’으로 국가정보원장이 공지한 제품
5. 제86조의2제2항에 따라 취약 정보통신제품을 긴급 대체하기 위하여 도입하는 제품

② 제1항제3호에 해당하는 제품은 실제 적용·운용하기 이전에 제2장 제5절에 따른 보안적합성 검증을 받아야 한다.

③ 제1항제5호에 해당하는 긴급 대체 제품을 도입한 정보화사업담당관은 빠른 시일 안에 원(原) 제품과 같은 수준의 안전성 확인이 이루어질 수 있도록 다음 각 호의 어느 하나에 해당하는 조치를 해야 하며, 필요시 국가정보원장에게 추가적인 검증을 요청할 수 있다.

1. 제1항제1호 및 제2호에 따른 도입요건을 갖출 것

2. 제3호 및 제2장제5절에 따른 보안적합성 검증 절차를 거칠 것

제20조(안전성 검증필 제품 목록) ① 정보시스템 관리책임자는 「국가정보보안기본지침」 제21조제1항 각 호에 따라 국가정보원장이 공정한 안전성 검증필 목록의 제품을 도입·운용해야 한다.

② 제1항에도 불구하고 정보시스템 관리책임자는 검증필 제품 목록에 등재되지 않은 제품을 도입하는 경우 도입하기 전에 정보보안담당관과 협의 후 해양수산부장관을 거쳐 국가정보원장에게 사전 보안적합성 검증을 신청해야 하며, 국가정보원장이 적합으로 판정한 이후에 도입·운용해야 한다.

제21조(검증필 암호모듈 목록 및 운용관리) ① 정보시스템 관리책임자는 「국가정보보안기본지침」 제22조제1항에 따라 국가정보원장이 공정한 검증필 암호모듈 목록의 제품을 도입·운용해야 한다.

② 제1항에도 불구하고 정보시스템 관리책임자는 검증필 암호모듈 목록에 등재되지 않은 제품을 도입하는 경우 도입하기 전에 정보보안담당

당관과 협의 후 해양수산부장관을 거쳐 국가정보원장에게 사전 보안 적합성 검증을 신청해야 하며, 국가정보원장이 적합으로 판정한 이후에 도입·운용해야 한다.

제22조(영상정보처리기기 도입) 정보시스템 관리책임자는 제77조제1항에 따른 영상정보처리기기를 도입할 경우 한국정보통신기술협회(TTA)의 공공기관용 보안 성능품질 인증 등 일정한 보안성능이 확인된 제품을 우선적으로 도입해야 한다.

제23조(도입현황 제출) ① 정보시스템 관리책임자는 제19조에 따라 도입한 모든 제품에 대해서는 별지 제2호서식에 따른 정보통신제품 도입확인서(현황)와 국가정보원장이 「해양수산부 정보보안업무규정」 제142조제2항의 방식으로 배포하는 제품유형별 운용점검사항을 제품 도입 후 10일 내로 정보보안담당관에게 제출해야 한다. 다만, 교육현장에 도입한 정보통신제품은 제외한다.

② 정보보안담당관은 제1항에 따라 정보시스템 관리책임자로부터 제출받은 정보통신제품 도입확인서(현황)를 매 분기마다 해양수산부장관에게 제출해야 한다.

제4절 계약 및 사업수행

제24조(계약 특수조건) ① 정보화사업담당관은 「국가를 당사자로 하는 계약에 관한 법률 시행령」 제76조제2항제3호다목에 따라 다음 각 호의 어느 하나에 해당하는 행위 등을 금지하는 내용의 계약 특수조건

을 계약서에 분명하게 적어야 하며 계약기간(하자 보증기간을 포함한다) 내에 발생한 보안약점 등에 대해서는 계약업체로 하여금 개선 조치하도록 해야 한다.

1. 정보통신망 또는 정보시스템 구축 및 유지보수 등의 계약 이행과정에서 정보통신망 또는 정보시스템에 허가 없이 접속하거나 무단으로 정보를 수집할 수 있는 비인가 프로그램을 설치하는 행위

2. 제1호의 행위에 악용될 수 있는 정보통신망 또는 정보시스템의 약점을 고의로 생성 또는 방치하는 행위

② 정보화사업담당관은 계약업체로부터 제1항과 관련한 행위가 없다는 확인서를 대표자 이름으로 제출받을 필요가 있다고 판단되는 경우 같은 내용을 계약서에 분명하게 밝힌 후 제출받아야 한다.

제25조(용역업체 보안) ① 정보화사업담당관은 용역업체에 정보화사업을 발주할 경우 다음 각 호의 보안사항을 준수하도록 계약서에 분명하게 적어야 한다.

1. 제12조제1항 각 호에 따른 제안요청서에 포함된 사항

1의2. 제27조에 따른 원격지 개발, 제28조에 따른 원격지에서의 온라인 개발, 제50조에 따른 온라인 유지보수를 허용할 경우 보안 준수사항

2. 소프트웨어 개발보안에 필요한 사항

3. 사업 참여인원의 보안관련 준수사항과 위반할 경우 손해배상 책임에 관한 사항

4. 사업 수행과 관련한 보안교육, 보안점검 및 사업기간 중 참여인원
임의 교체 금지
 5. 정보통신망 구성도·IP주소 현황 등 업체에 제공하는 자료는 자료
인계인수대장을 갖추어 보안 조치 후 인계인수하고 무단 복사 및
외부반출 금지
 6. 업체의 노트북·휴대용 저장매체 등 관련 장비는 반출·반입할 때
마다 악성코드에 감염되었는지 및 누출금지정보가 무단으로 반출되
었는지 등 점검
 7. 사업 종료 시 업체의 노트북·휴대용 저장매체 등 관련 장비는 저
장자료 복구가 불가하도록 완전 삭제
 8. 사업 종료 시 누출금지정보 전량 회수
 9. 그 밖에 정보보안담당관이 보안관리가 필요하다고 판단하는 사항
또는 국가정보원장이 보안 조치를 권고하는 사항
- ② 정보화사업담당관은 비밀 및 중요 용역사업을 수행할 경우 용역업
체 참여 인원이 다음 각 호에 해당하는 사실을 알게 된 경우 교체를
요구해야 한다.
1. 「국가공무원법」 제33조제3호부터 제6의4호까지에 해당하는 사람
 2. 「국가를 당사자로 하는 계약에 관한 법률」 제27조제1항 각 호의
행위를 한 사람
- ③ 정보화사업담당관은 다음 각 호에 따른 보안 준수사항을 이행했는
지 정기 또는 수시로 점검(불시 점검을 포함한다)하고 미비점을 발견

한 경우 용역업체로 하여금 시정 조치하도록 해야 한다. 이 경우 정보화사업담당관은 그 결과를 점검하고 정보보안담당관에게 통보해야 한다.

1. 제1항에 따라 계약서에 분명하게 적힌 보안 준수사항
2. 제26조의2에 따른 발주기관 내 작업장소 보안 준수사항
3. 제27조에 따른 원격지 개발 보안 및 제28조에 따른 원격지에서의 온라인 개발 시 보안 준수사항
4. 제49조에 따른 정보시스템 유지보수 및 제50조에 따른 온라인 유지보수 시 보안 준수사항

④ 정보보안담당관은 본원 및 소속기관의 용역업체 보안관리 실태를 자체 점검할 수 있다.

⑤ 정보화사업담당관은 제27조에 따른 원격지 개발, 제28조에 따른 원격지에서의 온라인 개발 또는 제50조에 따른 온라인 유지보수를 실시할 경우 자체 보안대책을 수립하여 정보보안담당관과 협의 후 해양수산부 정보보안담당관에게 승인을 요청해야 한다.

⑥ 정보보안담당관은 제3항 및 제4항에 따른 점검 결과 용역업체 보안대책 준수가 미흡하고 시정조치가 어렵다고 판단할 경우 해양수산부 정보보안담당관과 협의 후 제27조에 따른 원격지 개발, 제28조에 따른 원격지에서의 온라인 개발 또는 제50조에 따른 온라인 유지보수 허가를 취소할 수 있다.

⑦ 정보화사업담당관은 제28조에 따른 원격지에서의 온라인 개발, 제5

0조에 따른 온라인 유지보수를 허용할 경우에는 용역업체의 온라인 접속을 통제하기 위한 온라인 용역 통제시스템을 구축·운영해야 한다.

⑧ 그 밖에 용역업체 보안과 관련한 사항은 국가정보원장이 배포한 「국가·공공기관 용역업체 보안관리 가이드라인」과 해양수산부장관이 배포한 「용역업체 보안관리 가이드라인」을 준수해야 한다.

제26조(소프트웨어 개발보안) 정보화사업담당관은 정보시스템을 개발할 경우 「전자정부법」 제45조제3항에 따라 규정된 「행정기관 및 이에 따라 보안약점이 발생하지 않도록 개발(이하 "소프트웨어 개발보안"이라 한다)하고 정보시스템 감리 또는 해양수산부장관이 제공하는 소스코드 취약점 점검시스템 등을 통해 보안약점을 진단하고 조치해야 한다.

제26조의2(발주기관 내 작업장소 보안) ① 정보화사업담당관은 발주기관 내 (기관장이 임차한 외부 사무실을 포함한다) 용역업체 작업장소를 설치할 경우 보안 통제가 가능한 공간을 마련, 운영해야 한다.

② 발주기관 내 용역업체 작업장소에 설치·운영하는 정보통신망은 발주기관의 정보통신망과 분리 구성해야 한다. 다만, 용역업체가 사업수행을 위하여 발주기관 정보시스템 이용이 불가피할 경우에는 필요한 정보시스템에 한정하여 지정된 단말기로부터의 제한적 접근을 허용하는 등 보안대책을 수립·시행해야 한다.

③ 정보화사업담당관이 제2항 단서에 따라 용역업체에 지정된 단말기

로부터의 제한적 접근을 허용하려는 경우 내부망 정보시스템에 대한 접근 허용을 하려면 정보보안담당관을 거쳐 국가정보원장과 사전 협의해야 한다.

④ 작업장소 내 정보시스템은 용역사업 수행을 위하여 필요한 경우 해당 정보화사업담당관의 보안통제 아래 인터넷에 연결할 수 있다. 다만, 제2항 단서에 따른 발주기관 정보시스템 접근용 단말기의 경우에는 인터넷 연결을 금지한다.

⑤ 정보화사업담당관은 용역업체가 발주기관 내 작업장소에서 개발 작업을 수행하더라도 개발용 서버가 민간 클라우드컴퓨팅서비스를 이용하는 등의 사유로 원격지에 위치할 경우 원격지 개발로 보고 제27조 제1항에 따른 보안대책을 수립·시행해야 한다.

제27조(원격지 개발보안) ① 정보화사업담당관은 「소프트웨어 진흥법」 제49조제3항 및 제4항, 「소프트웨어사업 계약 및 관리감독에 관한 지침」 제14조에 따라 용역업체가 발주기관 이외 장소(이하 "원격지"라 한다)에서 개발 작업(유지보수는 제외한다)을 수행하려고 요청할 경우 제12조제1항제1호에 따른 용역업체 작업장소에 대한 보안요구사항 등을 포함한 관리적·기술적 보안대책을 수립·시행해야 한다. 이 경우 정보화사업담당관은 보안대책을 수립하고 정보보안담당관과 협의 후 해양수산부 정보보안담당관의 승인을 받아야 한다.

② 원격지 내 정보시스템은 개발 작업을 위하여 필요한 경우 해당 정보화사업담당관의 보안통제 아래 인터넷에 연결할 수 있다.

제28조(원격지에서의 온라인 개발) ① 제27조에 따른 원격지 개발에서 정보화사업담당관이 필요하다고 판단하고 용역업체가 다음 각 호에 따른 보안대책에 서면으로 동의하는 경우에 한정하여, 정보화사업담당관은 용역업체에게 원격지에서 인터넷을 통해 발주기관 정보시스템에 온라인 접속한 상태의 개발 작업(이하 "온라인 개발"이라 한다)을 허용할 수 있다.

1. 지정된 단말기에서만 접속 및 해당 단말기에 대한 접근인원 통제
 2. 지정 단말기는 제3호에 따른 온라인 용역 통제시스템 접속 전용으로 운용하고 다른 목적의 인터넷 접속은 차단
 3. 발주기관 내 설치한 온라인 용역 통제시스템을 거쳐 개발에 필요한 정보시스템에 접속하는 등 소통구간 보호·통제
 4. 접속사실이 기록된 로그기록을 1년 이상 보관
 5. 계약 시행일부터 종료 후 30일이 지나는 날까지의 기간 중에 발주기관, 해양수산부장관 및 국가정보원장의 정기 또는 수시 보안점검(불시 점검을 포함한다) 수검(受檢)
 6. 그 밖에 국가정보원장이 배포한 「국가·공공기관 용역업체 보안관리 가이드라인」에서 제시된 온라인 개발에 관련된 보안대책의 준수
- ② 정보화사업담당관이 제1항에 따라 온라인 개발을 허용하려는 경우 정보화사업담당관은 제1항 각 호의 내용을 포함한 보안대책을 수립한 후 과학원 정보보안담당관의 협의를 거쳐 해양수산부 정보보안담당관에게 승인을 받아야 한다.

제29조(소프트웨어 산출물 제공) ① 정보화사업담당관은 용역업체가

「소프트웨어 진흥법」 제59조 및 「(계약예규)용역계약일반조건」 제56조에 따른 지식재산권을 행사하기 위하여 소프트웨어 산출물의 반출을 요청할 경우 제안요청서 또는 계약서에 분명하게 명시한 누출 금지정보에 해당하지 않으면 이를 허용해야 한다.

② 정보화사업담당관은 제1항에 따라 소프트웨어 산출물을 용역업체에 제공할 경우 업체의 노트북·휴대용 저장매체 등 관련 장비에 저장되어 있는 누출금지정보를 완전 삭제해야 하며 업체로부터 누출금지 정보가 완전 삭제되었다는 대표자 이름의 확인서를 받아야 한다.

③ 정보화사업담당관은 용역업체가 소프트웨어 산출물을 제3자에게 제공할 경우 제공하기 이전에 승인을 받도록 해야 한다.

④ 그 밖에 소프트웨어 산출물 제공과 관련한 사항은 「소프트웨어사업 계약 및 관리감독에 관한 지침」 제32조를 준수해야 한다.

제30조(누출금지정보 유출 시 조치) ① 정보화사업담당관은 용역업체

가 제안요청서 또는 계약서에 분명하게 밝힌 누출금지정보를 유출한 사실을 알게 된 경우 업체를 대상으로 계약 위반에 따른 조치를 해야 한다. 이 경우 용역업체의 누출 금지정보 유출 사실을 알게 된 정보화사업담당관 또는 사업과 관계된 공무원 등은 즉시 정보보안담당관을 거쳐 원장에게 보고해야 한다.

② 제1항에 따라 용역업체의 누출금지정보 유출 사실을 원장이 보고 받은 경우 그 사실을 해양수산부장관 및 국가정보원장에게 통보해야

하고 「국가를 당사자로 하는 계약에 관한 법률 시행령」 제76조에 따라 입찰 참가자격 제한 등 관련조치를 해야 한다.

제5절 보안적합성 검증

제31조(대상 제품) 정보시스템 관리책임자는 제19조제1항제3호에 따른 보안기능이 있는 정보통신제품을 도입하는 경우 실제 적용·운용 이전에 안전성을 확인하기 위하여 보안적합성 검증을 받아야 한다.

제32조(검증기관 및 신청) 정보시스템 관리책임자는 제31조에 따른 보안적합성 검증을 받으려고 할 경우 정보보안담당관의 사전 협의를 거쳐 해양수산부장관에게 검증을 신청해야 한다. 다만, 해양수산부장관과 협의된 부분에 대해서는 자체적으로 검증을 실시할 수 있다.

제33조(검증 신청 시 제출물) ① 정보시스템 관리책임자는 제32조에 따라 보안적합성 검증을 신청할 경우 별표 3의 보안적합성 검증 신청 시 제출물에 해당하는 문서 등을 해양수산부장관에게 제출해야 한다.
② 제1항에 따라 검증을 신청한 정보시스템 관리책임자는 해양수산부장관이 필요하다고 판단하여 추가 자료를 요청할 경우 이를 제출해야 한다.

제34조(검증결과 통보 및 조치) 「해양수산부 정보보안업무규정」 제35조에 따른 안전성 시험 결과를 통보받은 정보시스템 관리책임자는 해당 조치를 실시하고 그 결과를 정보보안담당관을 거쳐 해양수산부장관에게 통보해야 한다.

제35조(취약점 조치) 정보시스템 관리책임자는 보안적합성 검증을 마친 제품에서 새로운 취약점을 발견한 경우 이를 제거 또는 보완하고 그 결과를 정보보안담당관의 검토 후 해양수산부장관을 거쳐 국가정보원장에게 통보해야 한다.

제36조(형상변경 및 용도변경 시 조치) 정보시스템 관리책임자는 보안적합성 검증을 마친 제품의 보안기능 등 형상 변경이 필요하거나 도입 목적 이외의 용도로 운용이 필요한 경우 정보보안담당관을 거쳐 해양수산부장관과 협의하여 재검증 등 필요한 조치를 해야 한다.

제37조(이행여부 확인) ① 정보보안담당관은 보안적합성 검증을 받은 제품에 대한 운용실태, 개선 조치를 이행하였는지 등을 확인할 수 있다.

② 정보보안담당관은 제1항에 따라 개선조치 이행 등을 확인한 결과 미비점을 발견한 경우 해당 제품을 운용하는 정보시스템 관리책임자에게 시정 조치를 요청할 수 있고, 해당 제품을 운용하는 정보시스템 관리책임자는 필요한 시정조치를 해야 한다.

제3장 정보통신망 및 정보시스템 보안

제1절 정보통신망 보안

제38조(내부망·인터넷망 분리) ① 정보보안담당관은 내부망과 기관 인터넷망을 분리·운영해야 한다.

② 정보보안담당관은 내부망과 기관 인터넷망을 분리·운영할 경우

다음 각 호의 사항을 포함한 보안대책을 수립·시행해야 한다.

1. 침입차단·탐지시스템 설치 등 비인가자 침입 차단대책
2. 네트워크 접근관리시스템 설치 등 비인가 장비의 내부망 접속 차단 대책
3. 내부망 정보시스템의 인터넷 접속 차단대책
4. 내부망과 기관 인터넷망 간 안전한 자료전송 대책
5. 그 밖에 국가정보원장이 배포한 「국가·공공기관 업무전산망 분리 및 자료 전송 보안가이드라인」에서 제시하는 보안대책

③ 분임정보보안담당관은 부서의 정보시스템에 배정되는 IP주소를 체계적으로 관리해야 하며, 공무원 등은 IP주소를 임의적으로 변경하여서는 안 된다.

④ 정보보안담당관은 비인가자로부터 내부망을 보호하기 위하여 네트워크주소변환기(NAT)를 이용하여 사설 IP주소체계를 구축·운영해야 하며, IP주소별로 정보시스템 접속을 통제하여 비인가 기기의 내부망 접속을 차단해야 한다.

⑤ 정보보안담당관은 분리된 내부망과 기관 인터넷망 간 자료전송을 위한 접점이 불가피한 경우 다음 각 호의 사항을 포함한 보안대책을 수립·시행해야 한다.

1. 침입차단·탐지시스템 설치·운영
2. 내부망과 기관 인터넷망 간 접점 최소화
3. 내부망과 기관 인터넷망 간 한 방향 전송장비 등을 이용한 자료전

송체계를 구축·운영하고 원본파일은 3개월 이상, 전송기록은 6개월 이상 보관

4. 정기적으로 전송실패 기록을 확인하고 악성코드가 유입되었는지 등 점검

5. 내부망 자료를 기관 인터넷망으로 전송할 경우 분임정보보안담당관 또는 결재권자의 사전 또는 사후 승인절차 마련

제39조(클라우드컴퓨팅 보안) ① 정보화사업담당관은 클라우드컴퓨팅(공공 클라우드 센터를 포함한다)을 자체 구축·운영할 경우 국가정보원장이 배포한 「국가·공공기관 클라우드컴퓨팅 보안가이드라인」에 구체적으로 밝힌 기관 자체 클라우드컴퓨팅 구축 보안기준에 따라 보안대책을 수립·시행해야 한다.

② 정보화사업담당관은 민간 클라우드컴퓨팅서비스를 이용하려고 할 경우 다음 각 호에 해당하는 사항을 준수해야 한다.

1. 국내에 위치한 정보시스템(인증서버, 로그 및 백업서버 등을 말한다)·관리주체에 의해 데이터가 저장·관리되는 서비스의 이용

2. 다음 각 목의 요건에 따라 일반 이용자용 서비스와 영역이 분리되어 제공되는 서비스[이하 "공공 전용(專用) 민간클라우드"라 한다]의 이용

가. 영역 분리는 일반 이용자용 서비스와 데이터 및 프로세스 등의 간섭없이 국가정보원 및 이용기관의 보안관제, 사고조사, 예방보안활동 유지를 위한 각종 환경을 만족해야 함

나. 영역 분리는 ‘시스템 중요도’에 따라 물리적 또는 논리적으로 구현
다. ‘시스템 중요도’ 분류는 별표 5의 기준 준용

3. 국가정보원장이 배포한 「국가 클라우드 컴퓨팅 보안가이드라인」
에서 정하는 바에 따라 국가정보원장이 게시하거나 게시 예정인 민
간 클라우드컴퓨팅서비스 이용

4. ‘내부망·인터넷망 분리’ 원칙 등 그 밖의 보안 관련사항은 「국가
정보보안기본지침」 및 「국가 클라우드 컴퓨팅 보안가이드라인」
준수

5. 민간 클라우드컴퓨팅서비스 사업자와 계약 시 해킹사고 및 장애 대
응, 재발 방지 등에 필요한 조치를 위해 국가정보원 및 이용기관의
보안관제 및 사고조사, 사이버공격 및 위협에 대한 예방 및 대응활동
등에 적극 협조하도록 하는 내용을 분명하게 적을 것

③ 내부망과 연동된 공공 전용 민간클라우드는 이 규정을 적용할 때
내부망으로 본다.

④ 기관 인터넷망과 연동된 공공 전용 민간클라우드는 이 규정을 적용
할 때 기관 인터넷망으로 본다.

⑤ 제2항에 따라 민간 클라우드컴퓨팅서비스를 이용하는 정보화사업
담당관은 클라우드컴퓨팅서비스 제공자가 누출금지정보를 유출한 경
우 제30조에 따른 조치를 해야 한다.

⑥ 제2항에 따라 이용하는 민간 클라우드컴퓨팅서비스의 제공자는 공
공 전용(專用) 민간클라우드 영역에 대해 정부 기관에 준하는 보안관

리 책임을 진다.

제40조(보안·네트워크장비 보안) ① 정보시스템 관리책임자는 침입 차단·탐지시스템, 스위치·라우터 등 기관 정보통신망 구성 또는 기관 정보보안 정책 전반에 영향을 미치는 보안·네트워크 장비를 설치·운용할 경우 다음 각 호의 사항을 포함한 보안대책을 수립·시행해야 한다.

1. 물리적으로 안전한 장소에 설치하여 비인가자의 무단접근 통제
2. 콘솔에서 관리함을 원칙으로 하되, 다음 각 목의 경우 청사 내 지정 단말기로부터의 접속 관리 허용

가. 장비 관리자의 접속

나. 제26조의2제2항 단서에 따른 발주기관 내 용역업체 작업장소에서
의 접속

② 보안·네트워크장비 관리자는 로그기록을 1년 이상 보관해야 하고 비인가자가 접속하였는지를 정기적으로 점검하여 그 결과를 정보보안 담당관에게 통보해야 한다.

③ 보안·네트워크장비 관리자는 침입차단·탐지시스템의 침입차단·탐지규칙(rule)의 생성 근거를 1년 이상 보관하고 정기적으로 필요성이 있는지 점검·갱신해야 한다.

제41조(무선랜 보안) ① 정보시스템 관리책임자는 내부망을 제외한 정보통신망에서 다음 각 호의 경우와 같이 청사 내에 무선랜(WiFi)을 구축·운용할 수 있다.

1. 기관 인터넷망에 중계기(AP)를 설치하여 제71조제1항에 따라 정보
보안담당관이 지급한 단말기의 접속만을 허용하는 업무용 무선랜
2. 상용 인터넷망에 중계기를 설치하여 제75조제1항 각 호에 따라 반
입한 공무원 등의 개인 소유 이동통신단말기의 접속만을 허용하는
무선랜
3. 상용 인터넷망에 중계기를 설치한 외부인 전용 무선랜
 - ② 정보시스템 관리책임자는 제1항에 따라 무선랜을 구축·운용할 경
우 정보보안담당관과 사전 협의를 해야 하며 국가정보원장이 배포한
「국가·공공기관의 무선랜 구축 및 RFID 보안가이드라인」을 준수
하여 보안대책을 수립·시행해야 한다.
 - ③ 제2항에 따른 보안대책을 수립할 경우 제1항제1호 및 제2호에 따른
무선랜에 대해서는 다음 각 호의 사항을 포함해야 한다.
 1. 네트워크 이름(SSID) 브로드캐스팅(broadcasting) 금지
 2. 추측이 어렵고 복잡한 네트워크 이름 사용
 3. WPA2 이상(256비트 이상)의 암호체계를 사용하여 소통자료 암호
화
 4. 비인가 단말기의 무선랜 접속 차단 및 무선랜 이용 단말기를 확인
하기 위한 IP주소 배정기록 등 보관
 5. IEEE 802.1X, AAA(Authentication Authorization Accounting) 등
의 기술에 따라 상호 인증을 수행하는 무선랜 인증제품 사용
 6. 무선침입방지시스템 설치 등 침입 차단대책

7. 내부망 정보시스템 또는 인접해 있는 다른 기관의 정보시스템이 해당 무선랜에 접속되지 않도록 하는 기술적 보안대책

8. 그 밖에 무선랜 단말기·중계기 등 구성요소별 분실·탈취·훼손·오용 등에 대비한 관리적·물리적 보안대책

④ 정보시스템 관리책임자는 제1항에 따라 무선랜을 구축·운용할 경우 제2항 및 제3항에 따른 보안대책의 적절성을 수시로 점검·보완해야 한다.

제42조(이동통신망 보안) ① 정보시스템 관리책임자는 이동통신망(HSDPA·WCDMA·LTE·5G 등)을 이용하여 시스템을 구축하거나 중요자료를 소통할 경우 암호화 및 비인가 단말기의 이동통신망 접속 차단 등 기술적 보안대책을 수립·시행해야 한다.

② 정보시스템 관리책임자는 제1항에 따라 이동통신망을 이용한 시스템을 구축·운용할 경우 정보보안담당관과 사전 협의를 해야 하며 과학원의 정보통신망과 혼용되지 않도록 해야 한다.

제43조(영상회의 보안) ① 정보시스템 관리책임자는 영상회의시스템을 구축·운용할 경우 통신망(국가정보통신망·전용선·인터넷 등) 암호화 등 보안대책을 수립·시행해야 한다.

② 정보시스템 관리책임자는 제1항에 따라 영상회의시스템을 구축·운용할 경우 정보보안담당관과 사전 협의를 해야 하며 영상회의시스템 보안과 관련한 사항은 국가정보원장이 배포한 「안전한 정보통신 환경 구현을 위한 네트워크 구축 가이드라인」 및 「원격업무 통합보안

매뉴얼」을 준수해야 한다.

③ 정보시스템 관리책임자는 다음 각 호의 구분에 따라 상용 소프트웨어에 탑재된 영상회의 서비스를 이용할 수 있다.

1. 비공개 업무자료를 취급하거나 회의 내용이 비공개 업무자료에 준한다고 판단할 경우: 영상·음성·업로드 데이터가 국내 서버로만 전송되는 상용 영상회의 소프트웨어(이하 "국내 영상회의 솔루션"이라 한다)를 활용
2. 공개 업무자료를 취급하거나, 회의 내용이 공개 업무자료에 준한다고 판단할 경우: 국내 영상회의 솔루션 또는 그 밖의 영상회의 소프트웨어를 활용

④ 제3항제1호에도 불구하고, 정보시스템 관리책임자는 다음 각 호의 어느 하나에 해당하는 등 정당한 사유가 있는 경우 국가정보원장과 협의하여 국내 영상회의 솔루션 이외의 소프트웨어를 일시적 또는 정기적으로 활용할 수 있다.

1. 안보·국익상 필요한 외국기관(외국군을 포함한다)과의 영상회의 시에 상대방이 국내 영상회의 솔루션을 활용할 수 없거나, 상대방이 국내 영상회의 솔루션 이외의 소프트웨어 활용을 제안할 경우
2. 정책자문 등의 목적으로 민간인과 영상회의 시에 상대방이 국내 영상회의 솔루션을 활용할 수 없는 경우

제44조(인터넷전화 보안) ① 정보시스템 관리책임자는 자체 인터넷전화시스템을 구축·운영하거나 민간 인터넷전화 사업자망을 이용할 경

우 다음 각 호의 사항을 포함한 보안대책을 수립·시행해야 한다.

1. 한국정보통신기술협회(TTA) verified ver.4 이상 보안규격으로 인증받은 행정기관용 인터넷전화시스템 설치·운용
2. 인터넷전화기에 대한 장치 및 사용자 인증
3. 제어신호 및 통화내용 등 데이터 암호화
4. 인터넷전화망과 다른 정보통신망과의 분리
5. 인터넷전화 전용 침입차단시스템 등 정보보호시스템 설치·운용
6. 백업체제 구축

② 정보시스템 관리책임자는 제1항에 따라 인터넷전화시스템을 구축·운용할 경우 정보보안담당관과 사전 협의를 해야 한다.

③ 정보시스템 관리책임자는 민간 인터넷전화 사업자망을 이용할 경우 해당 사업자로 하여금 서비스 제공 구간에 대한 보안대책을 수립하도록 해야 한다.

④ 그 밖의 인터넷전화 보안과 관련한 사항은 국가정보원장이 배포한 「국가·공공기관 인터넷전화 보안 가이드라인」을 준수해야 한다.

제45조(인터넷 사용제한) ① 정보보안담당관은 국가비상사태 및 대형 재해·재난의 발생, 사이버공격 등으로부터 정보통신망과 정보시스템의 정상적인 운영을 보장하기 위하여 공무원 등에 대한 인터넷 사용을 일부 제한할 수 있다.

② 정보보안담당관은 기관 인터넷망의 효율적인 운영 관리 및 악성코드 유입 차단을 위하여 게임·음란·도박 등 업무와 관련이 없는 인터

넷 이용을 차단해야 하며, 악성코드 유입 차단을 위하여 필요할 경우 제63조제4항에 따른 상용 정보통신서비스의 접속을 제한할 수 있다.

제46조(외교통신 보안) ① 분임정보보안담당관은 재외공관과 비밀 등 중요자료를 소통할 경우 국가정보원장이 개발하거나 안전성을 확인한 암호자재를 사용하는 외교정보통신망을 사용해야 한다.

② 분임정보보안담당관은 재외공관에 직원을 파견할 경우 해당 직원에게 파견 이전에 정보시스템 보안관리 방법 등 정보보안교육을 실시해야 하며 파견 후에는 정보보안업무에 대한 인계인수를 철저히 해야 한다.

③ 분임정보보안담당관은 주요인사의 외국방문 행사와 관련한 자료 및 장비 등을 접수·발송할 경우 외교정보통신망 또는 외교행낭 등 안전한 수단을 이용해야 하며 일반 국제전화·팩스·인터넷 등 보안성이 없는 정보통신수단을 이용해서는 안 된다.

④ 그 밖에 외교통신 보안과 관련한 세부사항은 국가정보원장이 제시하는 보안대책을 준수해야 한다.

제47조(재외사무소 정보보안점검) 원장은 외국에 사무소를 개설·운영할 경우 필요하면 정보보안담당관으로 하여금 해당 사무소의 정보통신망 및 정보시스템에 대한 보안관리 실태를 점검하고 취약요인을 개선할 수 있다.

제2절 정보시스템 보안

제48조(정보시스템 보안책임) ① 정보시스템 관리책임자 및 관리자는 서버·네트워크장비 등 부서가 공동으로 사용하는 정보시스템의 운용·관리에 대한 보안책임을 진다.

② 정보보안담당관은 정보시스템 운용과 관련하여 보안취약점을 발견하거나 보안대책 수립이 필요하다고 판단하는 경우 개별사용자, 정보시스템 관리책임자에게 개선 조치를 요구할 수 있으며 조치가 끝날 때까지 정보시스템의 운용을 제한할 수 있다.

제49조(정보시스템 유지보수) ① 정보시스템 관리책임자는 용역업체와 유지보수 계약을 통해 정보시스템의 유지보수를 진행할 경우 다음 각 호를 고려하여 유지보수 절차 및 문서화를 수립해야 한다.

1. 유지보수 인원에 대한 보안서약서 집행, 보안교육 등을 포함한 유지보수 인가 절차를 마련하고 인가된 인원만 유지보수에 참여
2. 결함이 의심되거나 발생한 결함, 예방 및 유지보수에 대한 기록 관리
3. 유지보수를 위하여 정보시스템을 원래 설치장소에서 다른 장소로 이동할 경우 통제수단 마련
4. 유지보수 일시 및 담당자 인적사항, 출입통제 조치사항, 작업수행 내용 등 기록 관리

② 정보시스템 관리자는 용역업체 등이 유지보수와 관련한 장비·도구 등을 제26조의2제1항에 따른 발주기관 내 용역업체 작업장소로 반출·반입할 경우 악성코드에 감염되었는지 및 자료를 무단으로 반출

하였는지 확인하는 등 보안조치를 실시하고 그 결과를 정보시스템 관리책임자에게 제출해야 한다.

③ 정보시스템 관리자는 직접 또는 용역업체와 유지보수 계약을 통해 정보시스템의 유지보수를 진행할 경우 콘솔 또는 지정된 단말기로부터의 접속만을 허용해야 한다.

④ 정보시스템 관리책임자는 소관 정보시스템의 중요도·가용성 등에 따라 등급을 분류하고 해당 등급에 맞게 정보 보존 및 관리, 장애관리, 보안관리 등을 수행해야 한다.

제50조(지정 단말기를 통한 온라인 유지보수) ① 제49조제3항에 따른 지정된 단말기를 통해 유지보수를 할 때 정보시스템 관리책임자가 필요하다고 판단하고 용역업체가 다음 각 호에 따른 보안대책에 서면으로 동의하는 경우에 한정하여, 정보시스템 관리책임자는 용역업체에게 내부망을 포함하여 소관 정보시스템(제40조제1항에 따른 보안·네트워크장비를 제외한다)의 인터넷을 통한 온라인 유지보수를 허용할 수 있다.

1. 지정된 장소에 설치한 지정된 단말기에서만 접속하도록 하고, 해당 단말기에 대한 접근인원 통제
2. 지정 단말기는 제3호에 따른 온라인 용역 통제시스템 접속 전용으로 운용하고 다른 목적의 인터넷 접속은 차단
3. 발주기관 내 설치한 온라인 용역 통제시스템을 거쳐 유지보수 대상 정보시스템에 접속하는 등 소통구간 보호·통제

4. 접속사실이 기록된 로그기록을 1년 이상 보관
5. 유지보수 계약 시행일부터 종료 후 30일이 지나는 날까지의 기간 중에 발주기관, 해양수산부장관 및 국가정보원장의 정기 또는 수시 점검(불시 점검을 포함한다) 수검
6. 그 밖에 국가정보원장이 배포한 「국가·공공기관 용역업체 보안관리 가이드라인」에서 제시된 온라인 유지보수에 관련된 보안대책의 준수

② 제1항에 따라 인터넷을 통한 온라인 유지보수를 허용하려는 경우 정보시스템 관리책임자는 제1항 각 호의 내용을 포함한 보안대책을 수립하고 과학원 정보보안담당관과 사전 협의 후 해양수산부 정보보안담당관에게 승인을 받아야 한다.

③ 제1항제2호 및 제3호에도 불구하고 온라인 용역 통제시스템이 구축되지 않은 상황에서 정보시스템 관리책임자는 온라인 유지보수를 즉시 실시하지 않고서는 기관 업무수행에 상당히 차질이 발생한다고 판단되는 경우 정보보안담당관의 승인을 받은 후 인터넷망 정보시스템에 한정하여 직접 접속하는 온라인 유지보수를 일시적으로 허용할 수 있다.

④ 그 밖에 정보시스템 온라인 유지보수 보안과 관련한 사항은 제25조를 준용한다.

제51조(서버 보안) ① 정보시스템 관리책임자는 서버를 도입·운용할 경우 사이버공격으로 인한 자료의 도난, 위조 및 변조 등에 대비하여

다음 각 호의 사항을 포함한 보안대책을 수립·시행해야 하며, 해당 부서 소관 서버의 운용·관리에 대한 보안책임을 진다.

1. 서버 내 저장자료의 업무별·자료별 중요도에 따라 개별사용자의 접근권한을 다르게 줄 것
 2. 개별사용자별 자료 접근범위를 서버에 등록해 인가했는지를 알아내도록 하고 인가된 범위 이외 자료 접근통제
 3. 서버 운용에 필요한 서비스 포트 이외 불필요한 서비스 포트 제거 및 관리자용 서비스와 개별사용자용 서비스 분리·운용
 4. 관리자용 서비스 접속 시 특정 IP주소가 배정된 관리자용 단말기 지정·운용
 5. 서버 설정 정보 및 저장자료에 대한 정기적 백업 실시
 6. 데이터베이스에 대해서는 개별사용자의 직접 접속 차단, 개인정보 등 중요정보 암호화 등 데이터베이스별 보안조치 실시
- ② 서버 관리자는 제1항에 따른 보안대책의 적절성을 수시로 확인해야 하며 연 1회 이상 서버 설정 정보와 저장자료의 도난, 위조 및 변조 가능성 등 보안취약점을 점검·보완해야 한다.

제51조의2(제어시스템 보안) ① 정보시스템 관리책임자는 연구시설·장비, 전력 등을 원격에서 감시·제어하기 위한 정보시스템(이하 "제어시스템"이라 한다)을 구축·운용할 경우 최신 백신 소프트웨어 설치, 응용프로그램 보안패치 및 침해사고 대응방안 등 보안대책을 수립·시행하고 취약점을 점검·제거해야 한다. 다만, 백신 소프트웨어 등

보안소프트웨어를 설치함으로써 제어시스템의 정상 운영에 차질을 가져올 경우 국가정보원장과 협의하여 설치하지 않을 수 있다.

② 그 밖에 제어시스템 보안과 관련한 사항은 국가정보원장이 배포한 「국가·공공기관 제어시스템 보안가이드라인」을 준수해야 한다.

제52조(공개 서버 보안) ① 정보시스템 관리책임자는 외부인에게 공개할 목적으로 웹서버 등 공개서버를 구축·운영하려고 할 경우 내부망과 분리된 영역(DMZ)에 설치해야 하며, 해당 공개서버의 운용·관리에 대한 보안책임을 진다.

② 정보시스템 관리책임자는 비인가자의 공개서버 저장자료 도난, 위조, 변조 및 분산서비스거부(DDoS) 공격 등에 대비해 침입차단·탐지 시스템 및 DDoS 대응장비 설치 등 보안대책을 수립·시행해야 한다.

③ 공개서버 관리자는 비인가자의 공개서버 내 비공개 정보에 대한 무단접근을 방지하기 위하여 서버에 접근할 수 있는 개별사용자를 제한하고 불필요한 계정은 삭제해야 한다.

④ 공개서버 관리자는 공개서버 서비스에 필요한 프로그램을 개발·시험하기 위하여 사용한 도구(컴파일러 등) 및 서비스와 관계가 없는 산출물은 개발 완료 후 삭제해야 한다.

⑤ 그 밖에 공개서버 보안과 관련한 사항은 제51조를 준용한다.

제53조(로그기록 보관) ① 정보시스템 관리책임자는 정보시스템의 효율적인 통제·관리 및 사고 발생 시 추적 등을 위하여 로그기록을 보관·관리해야 한다.

② 제1항에 따른 로그기록에는 다음 각 호의 사항을 포함해야 한다.

1. 접속자, 정보시스템·응용프로그램 등 접속대상
2. 로그인·오프, 자료의 열람·출력 등 작업 종류 및 시간
3. 접속 성공·실패 등 작업 결과
4. 전자우편 사용 등 외부발송 정보 등

③ 정보시스템 관리책임자는 로그기록을 생성하는 정보시스템의 경우 시간 동기화 프로토콜(NTP) 적용 등을 통해 정확한 기록을 보관해야 한다.

④ 정보시스템 관리책임자는 로그기록을 정기적으로 점검하고 점검 결과 비인가자의 접속시도, 자료의 위조, 변조 및 삭제 등 의심스러운 정황이나 위반한 사실을 발견한 경우 즉시 정보보안담당관에게 통보해야 한다.

⑤ 정보시스템 관리책임자는 로그기록을 1년 이상 보관해야 하며 로그기록의 위조, 변조 및 외부유출 방지대책을 수립·시행해야 한다.

제54조(업무용 통신단말기 보안) ① 정보시스템 관리책임자는 업무용 통신단말기를 이용해 업무자료 등 중요정보를 소통·관리하려고 할 경우 다음 각 호의 사항을 포함한 보안대책을 수립·시행해야 한다.

1. 통신단말기에 대한 장치 및 개별사용자 인증
 2. 제어신호 및 통화내용 등 데이터 암호화
 3. 분실·탈취·훼손 등에 대비한 관리적·물리적·기술적 보안대책
- ② 정보시스템 관리책임자는 제1항제1호에 따른 통신단말기 개별사용

자를 대상으로 인증 및 암호화에 필요한 디지털정보를 발급할 수 없을 경우 국가정보원장이 배포한 「정보통신기기 암호기술 적용지침」을 준수해야 한다.

③ 정보시스템 관리책임자는 주요 보직자가 안전한 통화를 위하여 사용하는 공용(公用) 휴대전화가 분실·훼손되지 않도록 현황을 관리해야 한다. 이 경우 정보시스템 관리책임자는 국가정보원장이 예외로 허용하는 운용방식이 아니면 「해양수산부 정보보안업무규정」 제115조에 따라 보안대책을 수립·시행해야 한다.

제55조(모바일 업무 보안) ① 정보시스템 관리책임자는 휴대전화·태블릿 PC 등을 이용한 모바일 업무환경(내부 행정업무, 현장 행정업무 및 대민서비스 업무 등)을 구축·운용하려고 할 경우 보안대책을 수립해야 하며 정보보안담당관과 사전 협의 후 해양수산부장관을 거쳐 국가정보원장과 협의하여 시행해야 한다.

② 정보시스템 관리책임자는 제1항의 업무수행을 위해 모바일 단말기를 구매·배부·활용할 경우 다음 각 호의 보안조치를 실시해야 한다.

1. 모바일 단말관리(MDM) 솔루션, 백신 등 보안소프트웨어 설치
2. 국가정보원의 보안성검토 결과 승인되지 않은 소프트웨어(어플리케이션) 설치 차단
3. 최소한의 이동통신망(LTE, 5G) 이용을 제외한 무선랜(WiFi), 블루투스(Bluetooth) 등 부가서비스 무선통신 차단(해외 출장 등 해외 반출 시에는 로밍 서비스를 이용한다)

4. 카메라, 마이크, 화면캡처 등 불필요한 기능 제거
 5. 단말 도난·분실 등을 대비하여 잠금, 초기화 등 원격 보안통제 기능 활성화
 6. 휴대용 저장매체 등 비인가 저장매체 접속차단
 7. 단말기 상태모니터링 이벤트에 대한 감사로그 저장·보관
- ③ 모바일 단말기 관리자는 제2항에 따라 배부된 단말기를 다음 각 호의 보안대책을 준수하여 관리해야 한다.
1. 외부 반출·반입 전후에 악성코드에 감염되었는지 및 중요자료를 저장하였는지 점검
 2. 수량 및 상태(최신 보안패치가 유지되고 있는지 및 비밀번호를 설정하였는지 등을 말한다)를 제9조에 따른 사이버보안진단 주간에 정기적으로 점검
 3. 잠금장치가 있는 보관장소에 안전하게 보관
- ④ 개별사용자는 제2항에 따라 모바일 단말기를 활용할 경우 다음 각 호의 보안대책을 준수해야 한다.
1. 비밀·대외비·비공개 자료는 임의저장·소통·열람 금지. 다만, 비공개 자료는 제63조제2항 및 제3항 각 호, 제63조의2에 해당하는 경우 처리할 수 있다.
 2. 사용과정에서 저장된 모든 업무자료는 업무수행 후 즉시 삭제
 3. 단말기에서 업무용 PC로 자료이동·소통 금지
 4. 유심칩 포트 등 물리적 보안을 위해 봉인한 보안스티커 훼손 또는

제거 금지

5. 비밀번호 또는 화면패턴 설정

6. 단말기 도난·분실, 침해사고, 보안스티커 훼손 등 특이사항이 발생한 경우 정보시스템 관리책임자를 거쳐 정보보안담당관에게 즉시 신고

⑤ 정보보안담당관은 제4항제6호에 따라 신고를 접수받을 경우 단말기 원격 잠금 및 초기화 등 필요한 보안조치를 실시해야 한다.

⑥ 그 밖에 모바일 업무 보안과 관련한 사항은 국가정보원장이 배포한 「국가·공공기관 모바일 활용업무에 대한 보안가이드라인」을 준수해야 한다.

제56조(사물인터넷 보안) ① 정보시스템 관리책임자는 사물인터넷을 이용한 시스템을 구축·운용하려고 할 경우 사물인터넷 기기 및 중요 데이터 등을 보호하기 위하여 보안대책을 수립·시행해야 한다.

② 정보시스템 관리책임자는 사물인터넷을 이용한 시스템을 구축·운용하려고 할 경우 내부망과 분리해야 한다. 다만, 내부망과 연동이 필요한 경우에는 망 간 자료전송제품 설치 등 보안대책을 수립해야 한다.

③ 정보시스템 관리책임자는 사물인터넷 서비스를 위한 소프트웨어를 개발할 경우 제26조를 준수해야 한다.

④ 그 밖에 사물인터넷 보안과 관련한 사항은 국가정보원장이 배포한 「국가·공공기관 사물인터넷(IoT) 보안가이드라인」을 준수해야 한다.

다.

제57조(원격근무 보안) ① 정보보안담당관은 공무원 등이 재택근무, 출장지 현장 근무 또는 파견 근무(「해양수산부 정보보안업무규정」 제48조의2에 따라 기관 정보통신망 전용 단말기를 설치 운영하는 경우는 제외한다) 시 인터넷을 통해 본인 인증을 거쳐 기관 정보시스템에 접속하여 온라인상으로 수행하는 업무(이하 "원격근무"라 한다)를 수행하게 할 수 있다.

② 제1항에 따른 원격근무를 위하여 접속할 수 있는 기관 정보시스템은 다음 각 호와 같다.

1. 기관 인터넷망에 위치한 서버 및 서버에서 구동되는 가상 PC
2. 제38조제2항제4호에 따른 방법을 통해 접속할 수 있는 내부망 서버 및 내부망 서버에서 구동되는 가상 PC

③ 제1항에 따른 원격근무로 취급할 수 있는 업무자료의 범위는 공개 및 비공개 업무자료로 한다.

④ 정보보안담당관은 원격근무를 시행하려고 할 경우 원격근무자가 GVPN 등 보안대책이 마련된 정보통신망을 이용하도록 해야 한다.

⑤ 원격근무자는 정보보안담당관이 원격근무용 단말기(개인 소유의 정보통신기기를 포함한다)의 보안을 위하여 수행하는 다음 각 호의 조치에 적극 협조해야 한다.

1. 정보보안담당관이 제공하는 보안소프트웨어 설치·운영
2. 사이버공격 등으로 인한 자료유출 사고 발생 시 정보보안담당관이

요청하는 점검 및 제82조제3항에 따른 자료제출 요청 협력

3. 소속된 기관에서 지급받은 단말기의 경우 제71조에 따른 단말기 보안대책 준수

⑥ 정보보안담당관은 원격근무자에게 제5항에 따른 보안조치 등이 포함된 보안서약서를 내게 하고 직위·임무에 부합한 정보시스템 접근 권한 배정 및 보직변경·퇴직 등 변동사항 발생 시 접근권한 조정 등의 절차를 마련·시행해야 한다.

⑦ 그 밖에 원격근무 보안과 관련한 사항은 국가정보원장이 배포한 「원격업무 통합보안매뉴얼」을 준수해야 한다.

제58조(국제회의 보안) ① 정보시스템 관리책임자는 국제협상 등 중요 국제회의를 위하여 PC·노트북 등 정보시스템을 국외 현지에서 설치·운용하려고 할 경우 관련 정보·자료가 유출되지 않도록 다음 각 호의 사항을 포함한 보안대책을 수립·시행해야 한다.

1. 설치장소에 대한 물리적 접근통제
2. 정보시스템 접근 통제 및 분실 방지 등 보안관리
3. 정보시스템 저장자료 암호화 등 자료 접근통제
4. 전화기·팩스 등 통신장비에 대한 도청방지

② 국제회의 참가자는 회의 상대방이 제공한 PC·노트북·휴대용 저장매체 등 정보시스템을 사용해서는 안 된다.

제59조(저장매체 불용처리) ① 정보시스템 관리책임자는 정보시스템 또는 저장매체[하드디스크·반도체 기반 저장장치(SSD) 등]를 외부

수리·교체·반납·양여·폐기·불용 처리하려고 할 경우 정보시스템 및 저장매체에 저장된 자료가 외부에 유출되지 않도록 자료 삭제 등 보안조치를 실시해야 한다. 이 경우 정보시스템 관리책임자 및 개별사용자는 정보보안담당관과 협의해야 한다.

② 제1항에 따라 자료를 삭제할 경우 저장매체별·자료별 차별화된 삭제 방법을 적용할 수 있다.

③ 비밀·대외비를 저장하거나 암호화키를 저장한 저장매체는 소각·파쇄·용해 등의 방법으로 완전히 파괴해야 한다.

④ 그 밖에 정보시스템 및 저장매체의 불용처리와 관련한 사항은 국가정보원장이 배포한 「정보시스템 저장매체 불용처리지침」을 준수해야 한다.

제3절 자료 보안

제60조(비밀의 전자적 처리) ① 분임정보보안담당관은 「보안업무규정」에 따라 비밀의 생산, 분류, 보관, 열람, 출력, 송수신, 이관 및 파괴 등을 전자적으로 처리할 수 있다.

② 분임정보보안담당관은 비밀을 전자적으로 처리하는 전(全) 과정에서 기밀성, 무결성, 인증 및 부인방지 등 보안성을 확보해야 하며 이를 위하여 국가정보원장이 개발하거나 안전성을 확인한 암호자재를 사용해야 한다.

③ 제1항에 따라 비밀을 전자적으로 처리할 경우 내부망PC에서 비밀

을 전자적으로 처리할 수 있다.

④ 종이문서로 출력된 비밀의 관리는 「보안업무규정」을 준수해야 한다.

제61조(비밀관리시스템 운용) ① 정보보안담당관은 국가정보원장이 개발·보급하는 비밀관리시스템을 도입·운용할 수 있다.

② 정보보안담당관은 비밀관리시스템을 구축할 경우 비밀의 생산·보관·유통 등 전반에 대하여 비밀관리시스템을 활용하여 비밀을 안전하게 관리해야 한다.

제62조(대외비의 전자적 처리) ① 분임정보보안담당관은 대외비를 전자적으로 처리하려고 할 경우에는 검증필 암호모듈을 사용하여 위조·변조·훼손 및 유출 등을 방지하기 위한 보안대책을 마련해야 한다.

② 분임정보보안담당관은 업무와 관계되지 않은 사람이 대외비를 열람, 복제·복사 및 배부할 수 없도록 보안대책을 수립·시행해야 한다.

제63조(비공개 업무자료 처리) ① 공무원 등은 비공개 업무자료를 다음 각 호의 어느 하나에 해당하는 방법으로만 처리해야 한다.

1. 내부망 PC 및 서버에 작성 및 저장·보관
 2. 정보보안담당관이 지급한 휴대용 저장매체에 작성 및 저장·보관
 3. 다음 각 목의 어느 하나에 해당하는 수단(이하 "업무자료 공식 소통 수단"이라 한다)을 이용한 수신·발신 또는 등재·열람
- 가. 정보보안담당관이 자체적으로 구축·운용하는 전자우편시스템

(이하 "기관 전자우편"이라 한다)

나. 공무원 등이 공동으로 사용할 목적으로 문화체육관광부장관이 구

축·운영하는 전자우편시스템(이하 "공직자통합메일"이라 한다)

다. 공무원 등이 다른 공무원 등과 자료를 공유하거나 소통하기 위하

여 사용하는 전용 소프트웨어(이하 "공공 전용 메신저"라 한다)

라. 국회사무처가 구축·운영하는 의정자료전자유통시스템 등 기관

간 업무자료를 소통하거나 공동으로 활용하기 위하여 구축한 정보
시스템

4. 그 밖에 다른 법규에 따라 허용되는 처리방법

② 공무원 등은 제1항에도 불구하고 다음 각 호의 어느 하나에 해당하
는 경우 정보보안담당관이 지급한 인터넷 PC 또는 출장용 노트북을
이용하여 비공개 업무자료를 처리할 수 있다.

1. 업무자료 공식 소통수단의 발신 또는 등재 기능을 이용하여 제2조
제15호다목의 문장 또는 문구 작성

2. 업무자료 공식 소통수단으로 수신·발신 또는 등재·열람하는 과정
에서의 일시적 저장

3. 「해양수산부 정보보안업무규정」 제40조제5항에 따른 기관 인터
넷망 PC에 작성·저장

4. 제43조제3항 및 제4항에 따라 영상회의 솔루션을 활용해 비공개 업
무자료의 화면 영상을 공유하기 위한 일시적 저장

③ 공무원 등은 제1항에도 불구하고 다음 각 호의 어느 하나에 해당하

는 경우에는 예외적으로 개인이 소유한 PC·휴대용 저장매체·휴대 전화 등을 이용하여 비공개 업무자료를 처리할 수 있다.

1. 업무자료 공식 소통수단의 발신 또는 등재 기능을 이용하여 제2조 제15호다목의 문장 또는 문구 작성
 2. 업무자료 공식 소통수단으로 수신·발신 또는 등재·열람 과정에서
의 일시적 저장
 3. 원격근무시스템에 접속하여 작성
 4. 「감염병의 예방 및 관리에 관한 법률」 제34조제1항에 따른 감염
병 위기관리 조치 등 대규모 질병·재난 발생 등 특별한 사정으로
재택근무를 하면서도 소속 또는 근무 중인 기관에 원격근무시스템이
구축되지 않은 경우
 5. 제43조제3항 및 제4항에 따라 영상회의 솔루션을 활용하여 비공개
업무자료의 화면 영상을 공유하기 위한 일시적 저장
 6. 국민의 생명·신체, 국가안보 및 공공의 안전 등을 위하여 긴급히
작성, 저장, 수신·발신이 필요하다고 정보보안담당관이 인정하는
경우
- ④ 공무원 등은 제3항제5호 및 제6호에 해당하는 경우를 제외하고는
「정보통신망 이용촉진 및 정보보호 등에 관한 법률」 제2조제1항제2
호에 따른 정보통신서비스(전자우편·메신저 등을 포함한다) 또는 국
외에서 제공하는 이와 유사한 서비스(이하 "상용 정보통신서비스"라
한다)를 이용하여 비공개 업무자료를 작성, 저장, 수신·발신해서는

안 된다.

⑤ 공무원 등은 제2항부터 제4항까지에 따라 작성·저장한 비공개 업무자료의 활용을 종료한 후에는 삭제해야 한다.

제63조의2(특정 상황별 비공개 업무자료 처리) ① 모든 공무원 등은 「국회법」 제128조제2항, 「국정감사 및 조사에 관한 법률」 제10조제2항, 「국회에서의 증언·감정 등에 관한 법률」 제2조 및 제4조에 따라 국회·정부 간 비공개 업무자료를 소통할 경우에는 우선적으로 제63조제1항제3호라목의 의정자료전자유통시스템을 활용하여 처리해야 하며, 시스템 장애 등 부득이한 사유로 활용이 곤란할 경우에만 제63조에 허용된 다른 방법으로 처리할 수 있다.

② 감독·감사·조사 등의 관계 법령에 따라 비공개 업무자료를 제출받을 권한이 있는 공무원 등은 업무자료를 제출할 상대방 공무원 등에게 제63조에 위반되는 방법으로 자료 제출을 요구해서는 안 된다.

③ 공무원 등이 자문 등의 목적으로 비공개 업무자료를 업무자료 공식소통수단을 활용할 수 없는 민간인에게 발신하거나 민간인으로부터 수신하려는 경우에는 공무원 등의 소속 기관 전자우편 또는 공직자 통합메일을 활용하여 발신하거나 수신해야 한다.

제64조(행정전자서명 인증서 등 관리) ① 공무원 등은 비공개 업무자료를 처리하기 위하여 「전자정부법」 제29조에 따른 행정전자서명의 인증서(이하 "행정전자서명 인증서"라 한다)를 인터넷 PC 또는 개인이 소유한 PC·휴대용 저장매체·휴대전화 등에 저장·보관할 수 있

다.

② 공무원 등은 행정전자서명 인증서 및 인증서의 비밀번호, 기관 전자우편 또는 공직자통합메일의 비밀번호 등을 상용 정보통신서비스를 이용하여 수신·발신하거나 저장·보관해서는 안 된다.

제65조(비공개 업무자료 유출방지) ① 정보보안담당관은 제63조에 따른 비공개 업무자료 처리 절차를 준수하였는지 관리·통제할 수 있는 보안체계를 구축·운영해야 하며, 검증필 암호모듈 등을 사용해 비공개 업무자료의 위조·변조·훼손 및 유출 등을 방지하기 위한 보안대책을 마련해야 한다.

② 정보보안담당관은 행정안전부장관이 개발 보급하는 다음 각 호에 해당하는 소프트웨어를 활용할 수 있다.

1. 제1항에 따른 보안체계 구축·운영을 위한 공통 소프트웨어
2. 원격근무시스템 구축·운용을 위한 소프트웨어
3. 공공 전용 메신저

③ 정보보안담당관은 공무원 등이 공공 전용 메신저 이용을 활성화할 수 있도록 노력해야 한다.

제66조(공개 업무자료 처리) ① 공무원 등은 관계 법규에 위배되지 않는 범위에서 인터넷 PC나 개인이 소유한 PC·휴대용 저장매체·휴대전화(기관 청사 내에서는 제75조제1항 각 호에 따라 반입한 경우를 말한다), 상용 정보통신서비스(기관 청사 내에서는 제45조제2항에 따른 제한이 없는 경우를 말한다) 등을 이용하여 공개 업무자료를 처리할

수 있다.

② 공무원 등이 제1항에 따라 기관 청사 내에서 상용 정보통신서비스를 사용하려는 경우에는 사용자, 사용목적 및 관리방안 등이 포함된 보안대책을 수립하여 분임정보보안담당관을 거쳐 정보보안담당관에게 사용 승인을 요청해야 하며, 정보보안담당관은 불가피한 경우에 한정하여 승인할 수 있다.

제67조(홈페이지 등 게시자료 보안) ① 정보보안담당관은 비공개 업무자료가 홈페이지 또는 외부 웹사이트(이하 "홈페이지 등"이라 한다)에 무단 게시되지 않도록 게시자료의 범위, 자료의 게시방법 등을 규정한 자체 홈페이지 정보공개 보안대책을 마련해야 한다.

② 분임정보보안담당관은 부서에서 홈페이지 등에 업무자료를 게시하려고 할 경우 자료 내용을 사전 검토하여 비공개 업무자료가 게시되지 않도록 해야 한다.

③ 분임정보보안담당관은 부서에서 운용하는 홈페이지에서 비공개 업무자료가 무단 게시되었는지를 정기적으로 점검해야 한다.

④ 분임정보보안담당관은 홈페이지 등에 비공개 업무자료가 무단 게시된 사실을 알게 된 경우 즉시 삭제하거나 차단 등 보안조치를 해야 한다.

제68조(정보통신망 현황자료 관리) ① 정보보안담당관은 다음 각 호에 해당하는 자료를 「공공기관의 정보공개에 관한 법률」 제9조제1항에 따른 비공개 대상 정보로 지정·관리해야 한다.

1. 정보통신망 구성현황(IP주소 배정현황을 포함한다. 이하 이 조에서 같다)

2. 정보시스템 운용현황

3. 취약점 분석·평가 결과물(「정보통신기반 보호법」 제9조에 따른 취약점 분석·평가결과를 포함한다. 이하 이 조에서 같다)

4. 주요 정보화사업 추진현황

② 제1항에도 불구하고 정보보안담당관은 다음 각 호에 해당하는 자료를 「보안업무규정 시행규칙」 제17조에 따라 국가정보원장이 배포한 「비밀세부분류지침」에 따라 비밀로 분류·관리해야 한다.

1. 국방 연구개발 및 정보통신 관련자료

2. 암호자재 운용현황

3. 「보안업무규정」 제32조에 따른 국가보안시설 및 국가보호장비의 운영·관리에 필요한 정보통신망 구성현황과 그에 대한 취약점 분석·평가 결과물

4. 그 밖에 제1항의 자료 중에서 국가정보원장이 비밀로 분류할 것을 요청한 자료

③ 정보보안담당관은 제1항 및 제2항에도 불구하고 다른 기관과 협력하여 정보통신망 및 정보시스템을 운용하거나 정보보안업무를 수행할 필요가 있는 경우 제1항 및 제2항 각 호에 해당하는 자료를 다른 기관의 장에게 제공할 수 있다.

제69조(빅 데이터 보안) ① 정보화사업담당관은 빅데이터와 관련한 시

시스템을 구축·운영하려고 할 경우 다음 각 호의 사항을 포함한 보안대책을 수립·시행해야 한다.

1. 데이터의 수집 출처 확인 및 데이터 오남용 방지
2. 데이터 수집을 위한 정보통신망 보안체계 수립
3. 수집된 데이터의 저장 및 보호체계 수립
4. 중요 데이터 암호화
5. 사용자별(데이터 제공자, 수집자, 분석요청자 및 분석결과 제공자 등) 권한배정 체계 수립
6. 데이터 파기절차 수립

② 그 밖에 빅데이터 보안과 관련한 사항은 개인정보보호위원회가 고시한 「개인정보의 안전성 확보조치 기준」 및 국가정보원장이 배포한 「국가·공공기관 빅데이터 보안 가이드라인」을 준수해야 한다.

제4절 사용자 보안

제70조(개별사용자 보안) ① 정보보안담당관은 소관 정보통신망 또는 정보시스템의 사용과 관련하여 다음 각 호의 사항을 포함한 개별사용자 보안에 관한 절차 및 방법을 마련해야 한다.

1. 직위·임무별 정보통신망 접근권한 배정 심사
2. 비밀 취급 시 비밀취급 인가, 보안서약서 제출 등 보안조치
3. 암호자재 취급 시 「해양수산부 정보보안업무규정」 제101조에 따라 암호취급자 지정·관리

4. 보직변경, 퇴직 등 변동사항 발생 시 정보시스템 접근권한 조정

② 개별사용자는 본인이 PC 등 정보시스템을 사용하거나 정보통신망에 접속하는 행위와 관련하여 스스로 보안책임을 진다.

제71조(단말기 보안) ① 개별사용자는 업무용으로 지급받은 PC·노트북·휴대전화·스마트패드 등 단말기(이하 "단말기"라 한다) 사용과 관련한 모든 보안관리 책임을 진다.

② 개별사용자는 단말기의 다음 각 호에 해당하는 보안대책을 준수해야 한다.

1. 시모스(CMOS)·로그온 비밀번호의 정기적 변경 사용
2. 단말기 작업을 10분 이상 중단 시 비밀번호 등을 적용한 화면보호 조치
3. 최신 백신 소프트웨어 설치
4. 운영체제 및 응용프로그램에 대한 최신 보안패치 유지
5. 출처, 유통경로 및 제작자가 불분명한 응용프로그램의 사용 금지
6. 인터넷을 통해 자료(파일) 획득 시 신뢰할 수 있는 인터넷사이트를 활용하고 자료(파일) 다운로드 시 최신 백신 소프트웨어로 검사 후 활용
7. 인터넷 파일공유·메신저·대화방 프로그램 등 업무상 불필요한 프로그램의 설치 금지 및 공유 폴더 삭제
8. 웹브라우저를 통해 서명되지 않은 액티브-X 등이 다운로드·실행되지 않도록 보안 설정

9. 인터넷 PC에서는 특별한 사유가 없을 때에는 문서프로그램을 읽기 전용으로 운용

10. 그 밖에 국가정보원장이 안전성을 확인하여 배포한 프로그램의 운용 및 보안권고문 이행

③ 제2항제9호에도 불구하고 공무원 등이 기관의 인터넷 PC에 편집이 가능한 문서프로그램을 운용하려는 경우에는 사용자, 사용목적, 관리방안 등이 포함된 보안대책을 수립하여 정보시스템 관리책임자를 거쳐 정보보안담당관과 사전 협의 후 해양수산부 정보보안담당관에게 사용 승인을 요청해야 한다.

④ 정보시스템 관리책임자는 개별사용자의 제2항 각 호에 해당하는 보안대책을 준수하는지를 정기적으로 점검하고 개선 조치해야 한다.

제72조(계정 관리) ① 정보보안담당관은 개별사용자에게 소관 정보통신망 또는 공용 정보시스템의 접속에 필요한 사용자 계정(아이디)을 배정하려고 할 경우 다음 각 호에 해당하는 사항을 준수해야 한다.

1. 개별사용자별 또는 그룹별 접근권한 배정
2. 외부인에게 계정을 배정하지 않되 업무상 불가피한 경우 정보보안담당관의 책임으로 보안 조치 후 필요한 업무에 한정하여 일정기간 동안 접속 허용
3. 특별한 사유가 없으면 용역업체 인원에게 관리자 계정 배정 금지
4. 비밀번호 등 식별 및 인증 수단이 없는 사용자 계정은 사용 금지

② 공용 정보시스템 관리자는 개별사용자가 시스템 접속(로그온)에 5

회 이상 실패할 경우 접속이 중단되도록 시스템을 설정하고 비인가자의 침입이 있었는지를 점검해야 한다.

③ 공용 정보시스템 관리자는 개별사용자의 보직변경, 퇴직, 계약종료 등 변동사항이 발생할 경우 신속히 사용자 계정을 삭제하거나 배정된 접근권한을 회수해야 한다.

④ 공용 정보시스템 관리자는 사용자 계정 배정 및 관리의 적절성을 주기적으로 점검해야 한다.

⑤ 공용 정보시스템 관리자는 제1항 및 제3항에 따른 접근권한 배정, 변경, 회수 또는 삭제 등에 대한 내용을 기록하고 3년 이상 보관해야 한다.

제73조(비밀번호 관리) ① 비밀번호를 설정할 경우 다음 각 호에 해당하는 사항을 반영하고 숫자·문자·특수문자 등 9자리 이상을 혼합하여 안전하게 설정하고 정기적으로 변경·사용해야 한다.

1. 사용자 계정(아이디)과 같지 않은 것
2. 개인 신상 및 부서 이름 등과 관계가 없는 것
3. 일반 사전에 등록된 단어의 사용을 피할 것
4. 같은 단어 또는 숫자를 반복하여 사용하지 말 것
5. 사용한 비밀번호는 재사용하지 말 것
6. 같은 비밀번호를 여러 사람이 공유하여 사용하지 말 것
7. 응용프로그램 등을 이용한 자동 비밀번호 입력기능을 사용하지 말 것

② 공용 정보시스템 관리자는 서버 등 정보시스템에 보관되는 비밀번호가 복호화되지 않도록 한 방향으로 암호화하여 저장해야 한다.

③ 정보보안담당관은 공용 정보시스템에서 개별사용자를 분별하여 알아보거나 인증하기 위하여 비밀번호에 같음하거나 병행하여 지문인식 등 생체인증 기술 및 일회용 비밀번호 생성기(OTP) 등을 안전성 확인 후 사용할 수 있다. 이 경우 생체인증 정보는 안전하게 보관해야 한다.

제74조(휴대용 저장매체 보안) ① 정보보안담당관은 각 부서에서 휴대

용 저장매체를 사용해 업무자료를 보관하려고 할 경우 자료의 위조·변조, 저장매체의 훼손·분실 등에 대비한 보안대책을 마련해야 한다.

② 정보보안담당관은 휴대용 저장매체 관리시스템을 운용하려고 할 경우 국가정보원장이 안전성을 확인한 제품을 도입해야 한다.

③ 정보보안담당관은 개별사용자가 휴대용 저장매체를 PC·서버 등에 연결할 경우 자동 실행되지 않고 최신 백신 소프트웨어로 악성코드가 있는지를 자동 검사하는 등의 보안 정책을 마련해야 한다.

④ 정보시스템 관리책임자는 휴대용 저장매체를 비밀용·일반용으로 구분·관리하고 수량 및 보관 상태를 정기적으로 점검하며 외부 반출·반입을 통제해야 한다.

⑤ 휴대용 저장매체 관리자는 비밀이 저장된 휴대용 저장매체는 매체별로 비밀등급 및 관리번호를 배정하고 비밀관리기록부에 등재·관리해야 한다. 이 경우 매체 앞면에 비밀등급 및 관리번호가 표시되도록 해야 한다.

⑥ 휴대용 저장매체 관리자는 비밀용 휴대용 저장매체를 다른 등급의 비밀용 또는 일반용으로 변경 사용하려고 할 경우 저장자료가 복구 불가하도록 완전 삭제 소프트웨어 등을 이용하여 삭제해야 한다. 다만, 완전삭제가 불가할 경우 변경 사용해서는 안 된다.

⑦ 휴대용 저장매체 관리자는 휴대용 저장매체를 폐기·불용 처리하려고 할 경우 저장자료가 복구 불가하도록 완전 삭제 소프트웨어 등을 이용하여 삭제해야 한다. 다만, 완전 삭제가 불가할 경우 파쇄해야 한다.

⑧ 정보시스템 관리책임자는 부서 개별사용자의 휴대용 저장매체 무단 반출, 미등록 휴대용 저장매체를 사용하는지 등 보안관리 실태를 제9조에 따른 사이버보안진단 주간에 정기적으로 점검해야 한다.

⑨ 그 밖에 휴대용 저장매체 보안과 관련한 사항은 국가정보원장이 배포한 「USB메모리 등 휴대용 저장매체 보안관리지침」을 준수해야 한다.

제75조(비인가 기기 통제) ① 공무원 등은 다음 각 호의 경우를 제외하고는 개인 소유의 정보통신기기를 무단 반입·사용해서는 안 된다.

1. 보편적 통신 목적의 개인 소유 이동통신단말기(LTE·5G 등 이동통신망 접속기능이 있는 휴대전화·태블릿·스마트워치): 반입하여 개인 용도로만 사용. 이 경우 반입 장비를 도크스테이션(dock station)·마우스·모니터·키보드 등 PC와 유사하게 활용토록 하는 장치와의 연결 사용을 금지한다.

2. 제1호를 제외한 정보통신기기: 제1호에 따른 반입·사용만으로는 보편적 통신 곤란 등 특별한 사정이 있는 경우에 한정하여 소속 부서의 분임정보보안담당관을 거쳐 정보보안담당관의 승인을 받아 반입 후 개인 용도로만 사용

② 공무원 등은 제1항 각 호에 따라 반입한 개인 소유의 정보통신기기를 내부망 및 기관 인터넷망(제41조제1항제1호에 따른 무선랜 형태를 포함한다)에 연결해서는 안 되며, 내부망 및 기관 인터넷망 정보시스템을 다른 정보통신망에 연결하는 수단으로 사용해서는 안 된다. 이 경우 분임정보보안담당관은 이를 수시로 점검해야 한다.

③ 정보보안담당관은 개인 소유의 정보통신기기가 업무자료를 외부로 유출하는 데 악용될 수 있거나 과학원의 정보통신망 운영에 위해(危害)를 입힐 수 있다고 판단할 경우 반출·반입 통제, 보안 소프트웨어의 설치 조건부 반입 등 보안대책을 수립·시행해야 한다.

제76조(규정 위반자 처리) 정보보안담당관은 정보보안 관련 규정을 어긴 사람의 처리에 대하여 다른 법규에 정하지 않은 경우는 별표 4의 해양수산부 정보보안 규정 위반자 처리 기준에 따른다.

제5절 융합 보안

제77조(영상정보처리기기 보안) ① 정보시스템 관리책임자는 업무상 목적으로 불특정 사람 또는 사물을 촬영한 영상을 유선이나 무선 정보통신망으로 전송·저장·분석하는 CCTV·IP카메라·이동형 영상촬

영상비·중계서버·관제서버·관리용 PC 등의 기기·장비(이하 "영상정보처리기기"이라 한다)를 설치·운용하려고 할 경우 운영자의 계정·비밀번호 설정 등 인증대책을 수립하고 특정 IP주소에서만 접속을 허용하는 등 비인가자 접근 통제대책을 마련해야 한다.

② 정보시스템 관리책임자는 영상정보처리기기를 통합·운용하는 시설(이하 "영상관제상황실"이라 한다)을 운영하려고 할 경우 영상관제상황실을 「보안업무규정」 제34조제2항에 따른 제한구역 또는 통제구역으로 지정·관리하고 출입통제 장치를 운용해야 한다.

③ 영상정보처리기기 관리자는 영상정보처리기기를 인터넷과 분리·운용해야 한다. 다만, 부득이하게 인터넷과 연결·사용해야 할 경우 전송내용을 암호화해야 한다.

④ 그 밖에 영상정보처리기기 보안과 관련한 사항은 국가정보원장이 배포한 「국가 공공기관 영상정보 처리기기 도입·운영 가이드라인」 및 「안전한 정보통신 환경 구현을 위한 네트워크 구축 가이드라인」을 준수해야 한다.

제78조(RFID 보안) ① 정보시스템 관리책임자는 RFID시스템(대상이 되는 사물 등에 RFID 태그를 부착하고 전파를 사용하여 해당 사물 등의 식별정보 및 주변 환경정보를 인식하여 각 사물 등의 정보를 수집·저장·가공 및 활용하는 시스템을 말한다)을 구축하여 중요정보를 소통하려고 할 경우 다음 각 호의 사항을 포함한 보안대책을 수립·시행해야 한다.

1. RFID시스템(태그 및 판독기를 포함한다) 분실·탈취 대비 및 백업 대책

2. 태그정보 최소화 대책

3. 장치 및 운용자 인증, 중요정보 암호화 대책

② 정보화사업담당관은 RFID시스템을 운영하는 경우 제1항과 관련한 보안대책의 적절성을 수시로 점검·보완해야 한다.

③ 그 밖에 RFID 보안과 관련한 사항은 국가정보원장이 배포한 「RF ID 보안관리 실무매뉴얼」을 준수해야 한다.

제79조(디지털복합기 보안) ① 분임정보보안담당관은 디지털복합기(디지털복사기 등도 포함한다. 이하 "복합기"라 한다)를 설치·운용하려고 할 경우 복합기 내 저장매체가 있거나 장착이 가능한 경우 자료유출을 방지하기 위하여 자료를 완전 삭제하거나 디스크 암호화 기능이 탑재된 복합기를 도입해야 한다.

② 복합기 관리자는 제1항에 따라 복합기를 설치·운용할 경우 다음 각 호의 사항을 포함한 보안대책을 수립·시행해야 한다.

1. 암호화 저장 기능이 있는 경우 해당 기능 사용

2. 정기적으로 저장된 작업 내용(출력·스캔 등) 완전 삭제

3. 공유 저장소 사용 제한 및 접근 제어

4. 고정 IP주소 설정 및 불필요한 서비스 제거

③ 복합기 관리자는 다음 각 호의 어느 하나에 해당하는 경우 복합기의 저장매체에 저장된 자료를 완전 삭제해야 한다.

1. 복합기 사용 가능 기간이 지나 폐기·양여할 경우
 2. 복합기 무상 보증기간 중 저장매체 또는 복합기 전체를 교체할 경우
 3. 고장 수리를 위한 외부 반출 등의 사유로 해당 기관이 복합기의 저장매체를 통제 관리할 수 없는 장소로 이동할 경우
 4. 그 밖에 저장자료의 삭제가 필요하다고 판단되는 경우
- ④ 복합기 관리자는 소모품 교체 등 복합기 유지보수를 할 경우 분임 정보보안담당관의 참석·감독 아래 실시하고 저장매체의 무단 교체 등을 예방해야 한다.
 - ⑤ 정보보안담당관은 복합기를 통해 내부망과 기관 인터넷망 간 접점이 발생하지 않도록 보안대책을 마련해야 한다.
 - ⑥ 분임정보보안담당관은 저장매체가 장착되어 있는 복합기 운용과 관련한 보안대책의 적절성을 수시로 자체 점검·보완해야 한다.
 - ⑦ 그 밖에 복합기 보안과 관련한 사항은 국가정보원장이 배포한 「정보시스템 저장매체 불용처리지침」을 준수해야 한다.

제80조(재난 방지대책) ① 정보시스템 관리책임자는 인위적 또는 자연적인 원인으로 인한 정보통신망의 장애 발생에 대비하여 정보시스템의 이중화, 백업관리 및 복구 등 종합적인 재난 방지대책을 수립·시행해야 한다.

- ② 정보시스템 관리자는 재난 방지대책을 정기적으로 시험·검토하고 재난으로 인해 업무에 지장을 줄 가능성에 대한 영향평가를 실시해야

한다.

③ 정보시스템 관리자는 정보통신망의 장애 발생에 대비하여 정보시스템 백업시설을 확보하고 정기적으로 백업을 실시해야 한다.

④ 정보시스템 관리자는 제3항에 따른 백업시설을 구축·운영하려고 할 경우 정보통신실·통합데이터센터와 물리적으로 일정거리 이상 떨어진 안전한 장소에 설치해야 하며 전력공급원 이중화 등 정보시스템의 가용성을 최대화할 수 있도록 해야 한다.

제4장 사이버위협 대응 및 훈련

제1절 사고 대응

제81조(사이버공격으로 인한 사고) ① 정보보안담당관은 「사이버안보 업무규정」 제16조에 따라 사이버공격·위협으로 사고가 발생한 경우 자체적으로 사고조사를 실시할 수 있으며, 해양수산부장관 및 국가정보원장이 사고 조사를 실시할 경우 이에 응해야 한다.

② 정보보안담당관은 제1항에 따라 사이버공격으로 인한 사고의 원인 분석 및 재발 방지를 위하여 피해 부서의 분임정보보안담당관에게 다음 각 호에 해당하는 자료 제출을 요청할 수 있다.

1. 공격 주체 및 피해자를 알아내기 위한 IP주소 및 MAC주소, 전자우편 주소, 정보통신서비스 이용자 계정 정보, 피해자의 성명 및 연락처
2. 사이버공격에 사용된 악성프로그램 및 공격 과정에서 생성·변경

또는 복제된 디지털정보

3. 공격 주체가 훔친 디지털정보

4. 공격 주체의 행위가 기록된 내용 또는 로그기록

③ 제2항에 따른 자료 제출을 요청받은 분임정보보안담당관은 관계 법규에 어긋나지 않는 범위에서 해당 자료를 제출해야 하며 정보보안 담당관은 제출받은 자료를 사고원인 분석, 공격자 의도 파악, 피해영향 평가 등 사이버공격에 대한 예방 및 대응과 관련한 목적으로만 사용해야 한다.

④ 피해 부서의 분임정보보안담당관은 사고 원인을 밝힐 때까지 피해 시스템에 대한 증거를 보존하고 임의로 관련 자료를 삭제하거나 포맷해서는 안 된다.

⑤ 공공 전용 민간클라우드를 이용하는 정보화사업담당관은 공공 전용 민간클라우드에서 사고가 발생한 경우 정보보안담당관과 협의 후 해양수산부장관과 합동으로 조사반을 구성하여 클라우드컴퓨팅서비스제공자에 대하여 계약의 범위에서 자료의 보존 및 제출 요구, 현장 조사 등 필요한 조치를 해야 한다.

제82조(정보통신보안 규정 위반 및 자료유출 사고) ① 정보보안담당관은 국가정보원장으로부터 「보안업무규정 시행규칙」 별표 2에 따른 정보통신보안규정 위반사항에 대한 사실을 통보받은 경우, 같은 규정 제6조제3항에 따라 즉시 필요한 조치를 하고 규정을 위반한 사람·내용 및 조치 결과를 해양수산부장관을 거쳐 국가정보원장에게 통보

해야 한다.

② 정보보안담당관은 비밀·대외비 등 국가 기밀에 속하는 업무자료가 유출되거나 비공개 업무자료가 유출된 사고 중 「국가정보원법」 제4조제1항제1호나목부터 마목까지와 관련된 사안일 경우 즉시 해양수산부장관과 국가정보원장에게 통보하여 합동 조사를 실시해야 한다.

③ 공무원 등의 과실로 개인 소유의 정보통신기기 및 이동통신단말기, 상용 정보통신서비스에서 제2항에 따른 유출사고가 발생한 경우 정보보안담당관은 해당 공무원 등에게 저장자료·이용내용 등의 자료 제출을 요청할 수 있다.

④ 공무원 등은 제3항에 따른 요청이 적법하다고 판단하는 경우 자료 제출을 해야 한다.

⑤ 정보보안담당관은 제1항 및 제2항에 따른 조사를 통해 유출을 확인한 자료에 대해서는 관계 기관의 장과 합동으로 국가안보, 국익 및 정부정책에 미치는 영향을 평가하여 필요한 조치를 해야 한다.

제83조(재발방지 조치) 정보보안담당관은 제81조 및 제82조에 따른 조사 결과 및 재발방지를 위한 보안조치 사항이 있거나 해양수산부장관 및 국가정보원장으로부터 통보 받은 경우 원장에게 보고를 하고 관계 법규에 따른 관련자 징계, 개선대책 수립·시행 등 필요한 조치를 해야 한다.

제84조(특례) 이 장에서 「국가사이버안전관리규정」 제12조 및 제13

조에 따라 규정된 사항을 적용할 때 「국가사이버안전관리규정」 제18조를 준수한다.

제2절 훈련 및 진단

- 제85조(사이버공격 대응훈련) ① 「사이버안보 업무규정」 제11조에 따라 사이버공격 대응훈련을 실시할 경우 분임정보보안담당관은 정보보안담당관이 총괄하는 사이버공격 대응훈련에 적극 협조해야 한다.
- ② 분임정보보안담당관은 부서의 모든 공무원 등이 훈련에 참여할 수 있도록 독려해야 한다.
- ③ 정보보안담당관은 사이버공격 대응훈련 결과 미흡한 부분이 있을 경우 해당 분임정보보안담당관에게 시정조치를 요청해야 하고, 요청 받은 분임정보보안담당관은 특별한 사유가 없는 한 즉시 시정조치해야 한다.
- ④ 정보보안담당관은 제3항에 따라 사이버공격 대응훈련 결과를 부서 성과평가 등에 반영할 수 있다.

- 제86조(진단·점검) ① 정보보안담당관은 「사이버안보 업무규정」 제12조제1항에 따른 진단·점검 또는 그 밖의 법규에 따라 정보통신망 보안진단·점검을 실시할 경우, 국가정보원장이 배포하는 다음 각 호의 지침 등을 참고해야 하며, 이에 필요한 관련예산 확보 등을 위하여 노력해야 한다.

1. 사이버보안 강화를 위한 길라잡이(정보통신시스템 보안진단 및 대

응방법을 포함한다)

2. 홈페이지·네트워크·시스템·데이터베이스 관리시스템(DBMS)

취약점 점검설명서

3. 정보보안점검 체크리스트

② 정보보안담당관은 소관 정보시스템이 주요정보통신기반시설로 지정되거나 행정안전부장관이 「전자정부법」에 따라 1·2등급으로 분류한 정보시스템인 경우 신규장비(서버, 네트워크장비, 정보보호시스템 등) 도입 시 서비스를 개시하기 전에 해양수산부장관에게 보안진단을 요청해야 한다.

③ 정보보안담당관은 제2항에도 불구하고 보안진단 대상 장비의 보안기능 비중이 낮은 경우 해양수산부장관과 협의하여 자체 보안진단을 실시할 수 있다. 이 경우 정보보안담당관은 보안진단 결과를 지체 없이 해양수산부장관에게 제출해야 한다.

④ 정보보안담당관은 제2항의 보안진단에 따라 취약점을 통보받은 경우 취약점을 조치하여 안전성을 확보한 후 정보시스템을 운영해야 한다.

제86조의2(취약 정보통신제품의 긴급 대체) ① 정보보안담당관은 제18조에 따른 보안기능이 있는 정보통신제품 중에서 취약점으로 인해 정보보안을 침해할 수 있는 타당하고 명백한 보안위협이 확인되고 시급한 조치가 필요하다고 판단한 경우 해당 정보통신제품을 도입한 정보시스템 관리책임자에게 운용중지를 요청할 수 있다.

② 제1항에 따라 요청을 받은 정보시스템 관리책임자는 지체 없이 운

용을 중단하고 정보보안에 취약점이 없는 같은 성능의 정보통신제품을 도입하여 대체해야 한다.

제5장 전산기계실 운영 및 백업 관리

제1절 전산기계실 관리·운영

- 제87조(전산기계실 관리일반)** ① 전산기계실을 운영하려는 경우 전산기계실 관리책임자 및 관리자를 지정·운영해야 하며 관리책임자는 전산기계실을 운영하는 부서의 장이 되고, 관리자는 업무담당자가 된다.
- ② 전산기계실 내는 항상 청결을 유지해야 하며, 전기 및 통신 배선은 관리자가 쉽게 알아볼 수 있도록 색인처리를 해야 한다.
- ③ 전산기계실은 비인가자의 접근으로 인한 안전사고를 예방해야 한다.
- ④ 전산기계실 내는 화기, 폭발성 물질 등의 위험물질을 반입할 수 없으며 부득이 반입하려는 경우는 전산기계실 관리자의 승인을 받은 후 반입해야 한다.
- ⑤ 전산기계실 관리자는 전산기계실 내에 설치·운영 중인 정보시스템 관련업무 담당자, 유지보수업체 기술지원 담당자의 비상연락망을 수시 현행화하여 관리해야 한다.

- 제88조(출입자 통제)** ① 전산기계실 관리자는 정보시스템에 대하여 외부로부터의 위해 방지를 위해 비인가자의 전산기계실 출입을 최대한 억제하고 다음 각 호와 같이 출입자를 통제해야 한다.

1. 출입하려는 자는 별지 제4호 전산기계실 출입자 관리대장 기록 및 승인을 받은 후 출입
 2. 전산기계실 관리자는 출입자와 동행하여 출입 목적에 부합된 작업을 하는지를 확인·감독 조치
- ② 전산기계실 내에서 시스템 관련 작업을 실시하는 경우 별지 제5호 전산기계실 작업신청서를 제출하여 전산기계실 관리자의 승인을 받은 후 작업을 실시해야 한다. 다만, 정보시스템 긴급 장애 발생 시에는 전산기계실 관리자에게 말로 알리고 선 조치 후 조치 결과를 포함하여 작업신청서를 작성 및 제출할 수 있다.

제89조(반출입 장비 통제) 전산기계실 내 전산장비 및 부품 반출입 시 별지 제6호 전산장비 반출입 관리대장에 기록하여 다음 각 호의 보안 조치를 한 후 전산기계실 관리자의 승인을 받은 후 반출입해야 한다.

1. 반입되는 모든 시스템의 기록매체는 악성코드, 바이러스 감염을 예방하기 위해 완전포맷 등 보안조치를 한 후 반입
2. 반출 장비 내에 자료가 저장되어 있는 경우는 백업 후 완전 포맷, 기록매체 분리 등 보안조치를 한 후 반출

제90조(부대장비 운영·관리) 전산기계실 관리책임자는 전산기계실 내 정보시스템의 보호를 위해 다음 각 호와 같이 부대장비를 설치·운영해야 하며, 부대장비들이 항상 정상작동 가능한 상태로 유지해야 한다.

1. 화재예방 및 조기진화를 위해 열·연기 감지 장치가 내장된 소화장비 설치·운영

2. 휴대용 비상조명, 휴대용 소화기 등 비상대응 용품
3. 정전에 대비하기 위해 무정전공급장치(UPS) 설치·운영
4. 적절한 온도 및 습도 유지를 위해 항온항습기 설치·운영

제91조(보안장비 운영) 전산기계실 관리책임자는 내부망과 기관 인터넷망과 달리 별도 통신망 구축하여 정보시스템을 운영할 경우 사이버 공격 등을 방어하기 위하여 방화벽, IPS 등 보안장비를 설치·운영해야 한다.

제2절 백업관리

제92조(백업관리 일반) ① 전산기계실 관리자는 정보시스템의 프로그램 및 자료는 백업정책에 따라 주기적으로 백업을 실시하고 백업수행 결과를 확인하여 기록·관리해야 한다.

② 전산기계실 관리자는 백업 결과를 확인 후 비정상 처리된 경우는 신속하게 전산기계실 관리책임자에게 보고해야 하며, 전산기계실 관리자는 원인을 분석하여 필요한 조치를 해야 한다.

③ 전산기계실 관리자는 백업데이터 및 서비스 복구 방법을 정기적으로 검토해야 한다.

제93조(백업자료 관리) ① 백업자료는 비인가자가 접근할 수 없는 잠금장치가 설치·운영 중인 장소에 보관해야 한다.

② 백업자료를 관리할 경우 비밀, 대외비, 공개제한, 비공개 보안등급의 백업자료는 비인가자가 접근할 수 없도록 이중 잠금장치가 설치·

운영 중인 장소에 보관해야 하며, 비인가자의 열람이 불가능하게 별도의 보안조치 후 보관해야 한다.

③ 백업매체를 테이프 등으로 보관하는 경우 백업일자, 테이프번호, 백업내용 등의 정보를 기록한 별지 제7호 서식 정보시스템 백업관리 대장에 기록·관리해야 한다.

제94조(백업자료 원격지 소산) ① 전산기계실 관리자는 물리적 재난에 대비하기 위해 주요 자료에 대한 Full백업 자료를 매 분기별 1회 이상, 20km이상의 원격지에 소산(疏散: 분산시킴)해야 한다.

② 전산기계실 관리자는 백업자료의 원격지 소산 장소를 공공기관의 제한구역 또는 통제구역으로 지정된 장소로서 비인가자의 접근이 불가능하고 잠금장치가 설치·운영 중이며 백업매체의 해손(害損)가능성이 없는 곳을 선정해야 한다.

③ 전산기계실 관리자는 원격지에 소산한 백업자료를 별지 제8호서식 백업자료 원격지 소산 대장에 기록·관리해야 한다.

제6장 보칙

제95조(재검토기한) 원장은 「훈령·예규 등의 발령 및 관리에 관한 규정」에 따라 이 훈령에 대하여 2024년 2월 1일 기준으로 매 3년이 되는 시점(매 3년째의 1월 31일까지를 말한다)마다 그 타당성을 검토하여 개선 등의 조치를 해야 한다.

부 칙

이 훈령은 발령한 날로부터 시행한다.

【 별표 1 】

IT보안제품 도입 사전인증요건

사전인증요건

- | | |
|--|---|
| ❶ 보안기능 시험제도(보안기능확인서)
❸ 성능평가제도
❺ 신속확인제도(신속확인서) | ❷ CC인증제도(CC인증서)
❹ 암호모듈검증제도 |
|--|---|

제품군	제품 유형	사전인증요건		
		‘가’ 그룹	‘나’ 그룹	‘다’ 그룹
침입차단 제품군	침입차단시스템(FW)	❶·❷ 중 어느 하나	❶·❷·❸ 중 어느 하나	자율지정
	침입차단시스템 (FW+VPN)	❶·❷ 중 어느 하나, 그리고 ❹	❶·❷·❸ 중 어느 하나, 그리고 ❹	
	웹 방화벽	❶·❷ 중 어느 하나	❶·❷·❸ 중 어느 하나	
	DDoS 대응장비	❶·❷·❸ 중 어느 하나	❶·❷·❸ 중 어느 하나	
	인터넷전화 보안제품	❶·❷ 중 어느 하나	❶·❷ 중 어느 하나	
	침입차단제품군에 속한 신기술·신종 제품	❶·❷ 중 어느 하나 (未발급제품은 도입후, 검증신청)	❶·❷·❹ 중 어느 하나 (未발급제품은 도입후, 검증신청)	
침입방지 제품군	침입방지시스템 (IPS·IDS)	❶·❷ 중 어느 하나	❶·❷·❸ 중 어느 하나	
	침입방지시스템 (IPS+VPN)	❶·❷ 중 어느 하나, 그리고 ❹	❶·❷·❸ 중 어느 하나, 그리고 ❹	
	무선침입방지제품 (WIPS)	❶·❷ 중 어느 하나	❶·❷ 중 어느 하나	
	침입방지제품군에 속한 신기술·신종 제품	❶·❷ 중 어느 하나 (未발급제품은 도입후, 검증신청)	❶·❷·❹ 중 어느 하나 (未발급제품은 도입후, 검증신청)	
구간보안 제품군	가상사설망(VPN)	❶·❷ 중 어느 하나, 그리고 ❹	❶·❷·❸ 중 어느 하나, 그리고 ❹	
	네트워크 접근통제 제품 (NAC)	❶·❷ 중 어느 하나	❶·❷ 중 어느 하나	
	망간자료전송제품	❶	❶·❷ 중 어느 하나	
	무선랜 인증제품	❶·❷ 중 어느 하나	❶·❷ 중 어느 하나	
	구간암호화제품	❹ (❶+❹ 권고)	❹ (❶+❹ 권고)	
	구간보안제품군에 속한 신기술·신종 제품	❶·❷ 중 어느 하나 (未발급제품은 도입후, 검증신청)	❶·❷·❹ 중 어느 하나 (未발급제품은 도입후, 검증신청)	
전송자료 보안 제품군	스팸메일차단시스템	❶·❷ 중 어느 하나	❶·❷ 중 어느 하나	
	네트워크 자료유출방지 제품(NDLP)	❶	❶·❷ 중 어느 하나	
	소프트웨어 보안USB 제품	❶ 그리고 ❹	❶·❷ 중 어느 하나, 그리고 ❹	

제품군	제품 유형	사전인증요건		
		‘가’ 그룹	‘나’ 그룹	‘다’ 그룹
	호스트 자료유출방지 제품(HDLP)	① 그리고 ④	①·② 중 어느 하나, 그리고 ④	
	메일암호화제품	④ (①+④ 권고)	④ (①+④ 권고)	
	전송자료보안제품군에 속한 신기술·신종 제품	①·② 중 어느 하나 (未발급제품은 도입후, 검증신청)	①·②·⑤ 중 어느 하나 (未발급제품은 도입후, 검증신청)	
보안관리 제품군	스마트카드(COS 포함)	①·② 중 어느 하나	①·② 중 어느 하나	
	통합보안관리제품 (ESM·통합로그관리등)	①·② 중 어느 하나	①·② 중 어느 하나	
	소스코드 보안약점 분석 도구	①·②·③ 중 어느 하나	①·②·③ 중 어느 하나	
	패치관리시스템	①·② 중 어느 하나	①·② 중 어느 하나	
	데이터베이스 접근통제 제품	①·② 중 어느 하나	①·② 중 어느 하나	
	통합인증제품(SSO)	①·② 중 어느 하나, 그리고 ④	①·② 중 어느 하나, 그리고 ④	
	보안관리제품군에 속한 신기술·신종 제품	①·② 중 어느 하나 (未발급제품은 도입후, 검증신청)	①·②·⑤ 중 어느 하나 (未발급제품은 도입후, 검증신청)	
가상화 제품군	가상화관리제품	①	①·② 중 어느 하나	
	가상화제품군에 속한 신기술·신종 제품	①·② 중 어느 하나 (未발급제품은 도입후, 검증신청)	①·②·⑤ 중 어느 하나 (未발급제품은 도입후, 검증신청)	
엔드포인트 보안제품군	디지털복합기	② (별도 검증신청 불요)	② (별도 검증신청 불요)	
	안티바이러스제품 (Windows용)	①·②·③ 중 어느 하나	①·②·③ 중 어느 하나	
	안티바이러스제품 (Linux용)	③	①·②·③ 중 어느 하나	
	스마트폰 보안관리제품 (MDM·EMM 등)	①·② 중 어느 하나	①·② 중 어느 하나	
	운영체제(서버) 접근통제 제품	①·② 중 어느 하나	①·② 중 어느 하나	
	문서암호화제품(DRM)	①·② 중 어느 하나, 그리고 ④	①·② 중 어느 하나, 그리고 ④	
	데이터베이스 암호화 제품	①·② 중 어느 하나, 그리고 ④	①·② 중 어느 하나, 그리고 ④	
	엔드포인트보안제품군에 속한 신기술·신종 제품	①·② 중 어느 하나 (未발급제품은 도입후, 검증신청)	①·②·⑤ 중 어느 하나 (未발급제품은 도입후, 검증신청)	
네트워크 장비	L3·L4·L7 스위치	①	①·② 중 어느 하나	
	라우터	①	①·② 중 어느 하나	
	SDN 컨트롤러	①	①·② 중 어느 하나	
	SDN 스위치	①	①·② 중 어느 하나	
	L2 보안시스템	①	①·② 중 어느 하나	
	네트워크장비에 속한 신기술·신종 제품	①	①·② 중 어느 하나	

【 별표 2 】

‘암호가 주기능인 제품’ 도입요건

제품 유형	도입 요건	비 고
메일 암호화제품	검증필 암호모듈 탑재	
구간 암호화제품		
하드웨어 보안토큰		
디스크·파일 암호화제품		
그 밖의 암호화제품		
SSO제품	검증필 암호모듈 탑재 및 CC인증(국가용 보호프로파일 준수)	
DB 암호화제품		
문서 암호화제품(DRM 등)		

※ 최신 도입요건은 국가정보원 홈페이지(암호모듈 검증) 참조

【 별표 3 】

보안적합성 검증 신청시 제출물

1. 최초 검증 신청 시 제출 서류

제출서류	정보보호시스템		작성 주체
	상용제품	자체(용역) 개발	
보안적합성 검증 신청서	○	○	신청기관
IT보안제품 도입확인서	○	○	
기술제안 요청서	○	○	
보안기능 점검표	○	○	
운용점검사항	○	○	
사전인증서 사본	○ (인증서 보유 시)	-	업체
보안기능 운용 설명서	○	○	
기본 및 상세 설계서	-	○	
개발완료 보고서	-	○	

2. 재검증 신청 시 제출 서류

제출서류	정보보호시스템		작성 주체
	상용 제품	자체(용역) 개발	
보안적합성 검증 신청서	○	○	신청기관
IT보안제품 도입확인서	○	○	
보안기능 점검표	○	○	
운용점검사항	○	○	
변경내용 분석서	○	○	업체

3. 생략 제품 도입 시 제출 서류

제출서류	정보보호 시스템	네트워크 장비	양자암호 통신장비	작성 주체
도입 확인서	○	○	○	신청기관
CC 인증서 또는 보안기능 시험 결과서 사본	○	○	○	
운용점검사항	○	-	-	
보안기능 운용 설명서	○	○	○	업체

해양수산부 정보보안 규정 위반자 처리 기준

1. 정의

- 사법처리: 「국가공무원법」, 「국가보안법」, 「군사기밀보호법」, 「형법」, 「통신비밀보호법」, 「정보통신기반보호법」, 「공무원 징계령」 등 관련 법률에 따른 보안사고 처벌
 - * 사법처리와 징계는 함께 부과 가능
- 중 징 계: 보안사고 원인을 제공하거나 보안위반으로 인한 피해 정도가 심각하여 엄히 책임을 묻는 처벌
- 경 징 계: 보안위반으로 인한 피해정도가 경미하나 군사기밀(자료) 보호 및 유사 보안위반 재발 방지를 위한 처벌
- 경 고: 보안위반 행위나 피해정도가 경미하나 비위의 정도가 주의보다 심각하여 보안위반자에게 과오를 반성하도록 엄중 훈계할 필요가 있는 경우
- 주 의: 보안위반 행위나 피해정도가 경미하다고 판단되어 그 과오를 반성하게 하고 앞으로 그러한 행위를 다시 하지 않도록 보안위반자에게 경각심을 고취하기 위한 처벌

2. 세부 처리기준

구분 항목	위 반 내 용		처리기준				
			사 법 처 리	중 징 계	경 징 계	경 고	주 의
보안시스템 관리 위반	분실 후 미회수	미신고	○	○			
		신 고		○	○		
	분실 후 회수	미신고		○			
		신 고			○	○	
	보안시스템을 고의적으로 유기			○			
	보안시스템을 비인가자가 관리 취급				○	○	
	암호자재·암호장비 사용법 미준수				○	○	
	보안자재를 불법 복제·복사·촬영하거나 암호자재를 외부 정보통신망에 게시		○	○	○		
	교육 및 전파할 목적으로 보안자재를 불법 복제·복사·촬영하여 전산망에 게시			○	○		
	보안자재를 과실로 전산망에 게시			○	○		
정보통신망 및 정보시스템 관리 위반	국가 정보통신망 및 정보시스템 대상 고의적 해킹 및 악성코드 유포		○	○			
	국가 정보통신망 및 정보시스템 대상 손괴 및 부정 사용, 비인가 프로그램 사용 등 고의적으로 장애 발생			○			
	사이버공격으로 인한 정보시스템 피해 발생	비밀 및 대외비 유출		○			
		비공개 업무자료 유출			○		
		과실에 의한 악성코드 감염 및 피해 심각(중요자료 대량유출 또는 2개망 이상 전파 등)		○	○		
		과실에 의한 악성코드 감염				○	○
	비인가 정보통신기기를 무단으로 반입하여 사용				○	○	
	기관 정보통신기기 임의 반출				○	○	
	사이버공격(해킹, 악성코드 감염 등) 침해사고 인지 후 미신고				○	○	
	사이버공격으로 인한 정보시스템 및 정보통신망 훼손 등 정당한 조사행위 방해				○	○	
	공격자가 인지한 계정정보(이메일 주소 등) 변경사용 권고 후에도 지속 사용				○	○	
	해킹·악성코드 등 사이버공격 예방대책 미강구					○	○

구분 항목	위 반 내 용		처리기준				
			사 법 처 리	중 징 계	경 징 계	경 고	주 의
	외부망 (인터넷)	비밀을 임의저장·게시·공유·전송	○	○			
		대외비를 임의저장·게시·공유·전송		○	○		
		비공개 업무자료를 임의저장·게시·공유·전송			○	○	
		외부전산망을 무단 설치·운용		○	○		
		내부망용(업무용) 저장매체(USB 등)를 인터넷 PC에 무단 접속하여 사용			○		
	내부망 (업무망)	비밀을 임의저장·게시·공유·전송	○	○	○		
		대외비를 임의저장·게시·공유·전송		○	○	○	
		외부망과 임의 연동하거나 불법접속		○	○	○	
	업무용 모바일 단말기	비밀, 대외비 자료 임의저장·소통·열람		○	○		
		비밀, 대외비 자료 임의저장·소통·열람			○	○	
		유심칩 포트를 봉인한 보안스티커 훼손				○	○
		필수 보안프로그램(백신, 단말관리 솔루션 등) 임의제거 및 우회하여 사용			○	○	○
		단말기에서 업무망PC로 임의 자료이동·소통			○	○	○
		비밀번호 또는 화면패턴 미 설정				○	○
		단말기 도난·분실, 침해사고 등 특이사항 발생 후 미 신고			○	○	○
		공직 기강 및 품위 훼손을 일으키는 등 업무와 무관한 자료 또는 소프트웨어 게시				○	○
		정보시스템 불용처리 시 저장매체 미삭제·미소거 처리			○	○	
		정보시스템을 무력화·우회·편법 사용할 목적으로 관련기법을 전파 또는 공유			○	○	
		필수 보안프로그램(백신, 매체제어 프로그램 등) 미 설치 또는 우회하여 정보시스템 사용			○	○	
		외부업체 직원의 전산망 임의 접속, 자료 열람, 악성코드 유포 등의 결과를 가져온 업무담당자			○	○	
		국가 정보통신망 내 비인가 서버구축 및 서비스(홈페이지, 게시판, FTP, 게임 등) 운용			○	○	
		보안대책 검토 및 보안측정 등 보안절차를 준수하지 않거나 검토·측정결과 조치 미흡			○	○	○
		사전승인(협의) 및 보안성검토·적합성검증 없이 정보시스템 개발·도입			○	○	○

구분 항목	위 반 내 용					처리기준				
						사 법 처 리	중 징 계	경 징 계	경 고	주 의
	노트북·PC 등 단말기 안 비인가된 무선통신 기능 미제거								○	○
	비밀번호 누설·도용 및 타인계정 무단 사용							○		
	비밀번호 운용규정 미 준수							○	○	○
저장 (보조기억) 매체 관리위반	무단반출	비밀용					○			
		대외비용						○		
		일반 업무용							○	○
	분실	비밀/ 대외비용	자료 보관	분실 후 미회수	미신고	○	○			
					신 고		○	○		
			분실 후 회수	미신고		○	○			
				신 고		○	○	○		
			자료 미 보관		미신고				○	
					신 고					○
		일반용	분실 후 미회수		미신고			○	○	
					신 고				○	○
			분실 후 회수		미신고				○	
					신 고					○
	파기	비밀용 저장매체 무단 파기					○	○		
		대외비용 저장매체 무단 파기						○		
		일반용 저장매체 무단 파기							○	○
	비인가 매체 반입	비밀 저장					○	○		
		대외비 저장						○		
		단순 반입							○	○
그 밖의 사항	경고(징계유예, 서면경고 등) 2회 이상 처벌 받은 사람이 재워반한 때							○		
	관련 법률에 따른 사법처리 대상이 되는 모든 정보 보안 사고						○			
	그 밖의 국가정보원 「국가 정보보안 기본지침」, 우리부 「정보보안 업무규정」이 정한 규정위반 시 사안의 심각성에 따라 처리							○	○	○

※ 세부 처리기준·절차와 감경·가중처리 기준 등은 「공무원 징계령」 및 「해양수산부 소속공무원의 복무관리지침」 준용

【 별표 5 】

클라우드 서비스 이용 ‘시스템 중요도’ 등급 분류기준

등급	분류기준		영역분리
상	파급영향	- 해당 정보시스템에 대한 침해는 운영기관, 자산 및 개인에게 치명적 악영향을 미칠 수 있음	물리적
	분류기준	- 국가 중대 이익(안보, 국가안전, 국방, 통일, 외교 등), 수사·재판 등 민감정보를 포함하거나 행정 내부업무 등을 운영하는 시스템	
중	파급영향	- 해당 정보시스템에 대한 침해는 운영기관, 자산 및 개인에게 심각한 영향을 미칠 수 있음	물리적
	분류기준	- 비공개 업무자료를 포함 또는 운영하는 시스템	
하	파급영향	- 해당 정보시스템에 대한 침해는 운영기관, 자산 및 개인에게 제한적인 영향을 미칠 수 있음	물리적 또는 논리적
	분류기준	- 개인정보를 포함하지 않고 공개된 공공데이터를 포함 또는 운영하는 시스템	

[표] 시스템 중요도 등급 분류기준 및 영역분리

- ※ 행정 내부업무의 경우 ‘시스템 중요도’ 를 고려하여 등급 조정 가능
- ※ 위 분류기준에 따른 분류 절차 및 체크리스트 등 세부사항은 ‘국가 클라우드서비스 보안가이드라인’ 을 참고한다.
- ※ 이용기관은 민간 클라우드서비스 도입시 시스템 등급을 자체 분류하고, 국정원은 ‘보안성 검토’ 시 분류의 적정성을 재검토한다.

보안적합성 검증 신청서

신청 기관	기관명		담당자	
	부서명		전화번호	
	사업명		전자우편 ※ 상용메일 불가	
	도입 목적			
	보안성 검토명		계약 날짜	
			도입 날짜	
검증결과 반영		취약점 등의 개선요청 이행 (☐ 반영 · 개선 ☐ 반영불가)		
신청 제품	제품명	※ 신청 제품이 두 종류 이상인 경우, 별도 신청	S/W(펌웨어) 버전	
	제품 유형		도입 수량	대
	사전 인증 대상 여부	☐ CC인증 대상 ☐ 검증필 암호모듈 탑재 ☐ 해당 없음 ※ CC인증 · 검증필 암호모듈 탑재 필수 제품은 국정원 홈페이지 참조		
	해시값 (SHA-512)	※ 해시값은 국정원 홈페이지에 게시된 S/W 사용		
	CC 인증기관		CC 인증등급	
	CC 인증번호		CC 만료일	
	암호모듈명		암호검증 번호	CM-
	업체	업체명		대표자
주소				
담당자명			전화번호	
휴대전화번호			전자우편	

※ △서식이 변경될 수 있으므로 국가사이버안보센터 홈페이지(보안적합성 검증 → 공지사항)에 게시된 서식을 참고 △'검증결과 반영'을 포함하여 기록 양식 중 해당사항은 빠짐없이 기록

【 별지 제2호서식 】

정보통신제품 도입 확인서(현황)

기관명		관계 중앙행정기관	
담당자		담당자 전화번호	
사업명			
보안성	보안성 검토받은 문서 제목 및 번호 표시 예) 000 보안성 검토결과(000-000, 2019.1.1)		

기관명	관계 중앙행 정기관	제품명	제조사	제품 유형	보안기능 확인서			CC인증, GS인증, 성능평가			암호모듈검증 (KCMVP)		펌웨어 또는 OS버전	해시값 (SHA- 512)	비고
					발급 번호	시험 기관	발급일	인증 번호	등급 또는 준수PP	인증 기관	암호 모듈명	암호 검증 번호			
				L3 스위치	ND-000 1-0001- 2019		2019-01 -01		NDcPP			CM-00- 000.0	이름 또는 버전		수량 등

※ △서식이 변경될 수 있으므로 국가사이버안보센터 홈페이지(보안적합성 검증 → 공지사항)에 게시된 양식을 참고하되, 반드시 엑셀(xlsx)양식을 준수 △해시값은 국가정보원 홈페이지에 등재된 S/W 활용

【 별지 제3호서식 】

정보시스템 관리대장

연번	소속	취급자 성명	종류 (서버·PC 등)	제조사	모델명	관리번호	도입일자	비고

【 별지 제4호서식 】

전산기계실 출입자 관리대장

출입자		출입사항				입회자
소속	성명	목적	출입일자 (YYMMDD)	입실시간	퇴실시간	

【 별지 제5호서식 】

전산기계실 작업신청서

결	담당자	관리책임자
재		

신청인	부 서 명		성 명	
	전 화 번 호		작업일자	
	작업개시	시 분	작업종료	시 분
시스템명			작업분류	☐ 장애 ☐ 수정 ☐ 기타
작업내용 (자세히 작성)	<i>작업내용, 작업자 연락처 등</i>			
조치결과				

상기와 같이 전산기계실 작업신청서를 제출합니다.

20 년 월 일

신청인 (인)

확인자 (인)

【 별지 제6호서식 】

전산장비 반출입 관리대장

사업명	소속	사용자	사유	모델명	S/N	반입 일자	반출 일자	사업담당자 (확인서명)				악성코드 감염 및 자료 무단반출 점검			
								반입		반출		반입		반출	

【 별지 제7호서식 】

정보시스템 백업관리 대장

[illegible]

【 별지 제8호서식 】

백업자료 원격지 소산 대장

[illegible]